

Responsabilidad compartida y defensa en profundidad

Parte 1 de 4 · Unidad 1

Ing. Rodolfo Cañas Cervantes

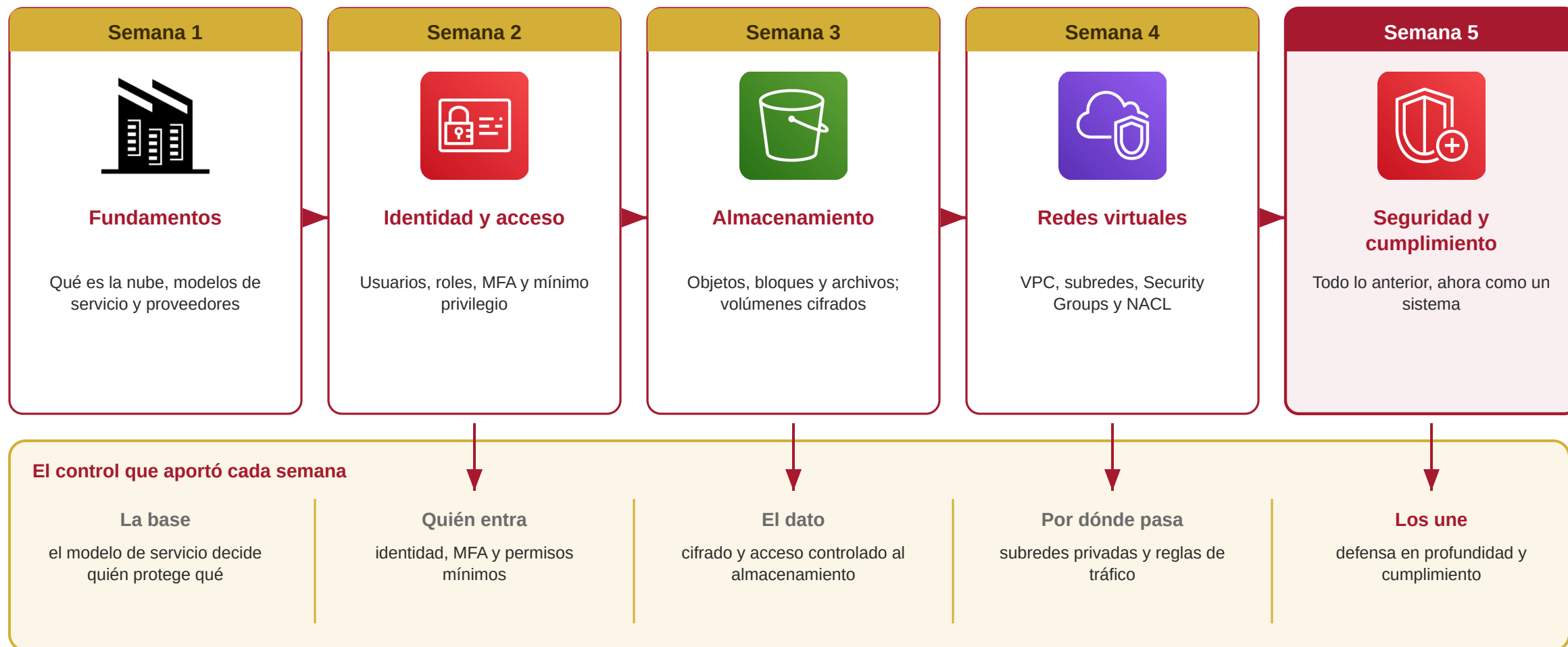
Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

Seguridad y cumplimiento en la nube: modelo de responsabilidad compartida, cifrado en reposo/tránsito, marcos de cumplimiento

Seguridad cierra la Unidad 1

Cada semana aportó un control; hoy los unimos en un solo sistema de defensa.



Ya construiste controles sin llamarlos así

Identidad, datos y red de las semanas 2, 3 y 4 son los controles de seguridad más básicos.

Semana 2 · Identidad



¿Quién eres y qué puedes hacer?

- ✓ Usuarios, grupos y roles
- ✓ MFA en la cuenta raíz
- ✓ Mínimo privilegio

+

Semana 3 · Datos



¿El dato está protegido?

- ✓ Bucket sin acceso público
- ✓ Volúmenes cifrados
- ✓ Versionado y copias

+

Semana 4 · Red



¿Quién habla con quién?

- ✓ BD en subred privada
- ✓ Security Groups por rol
- ✓ NACL por subred



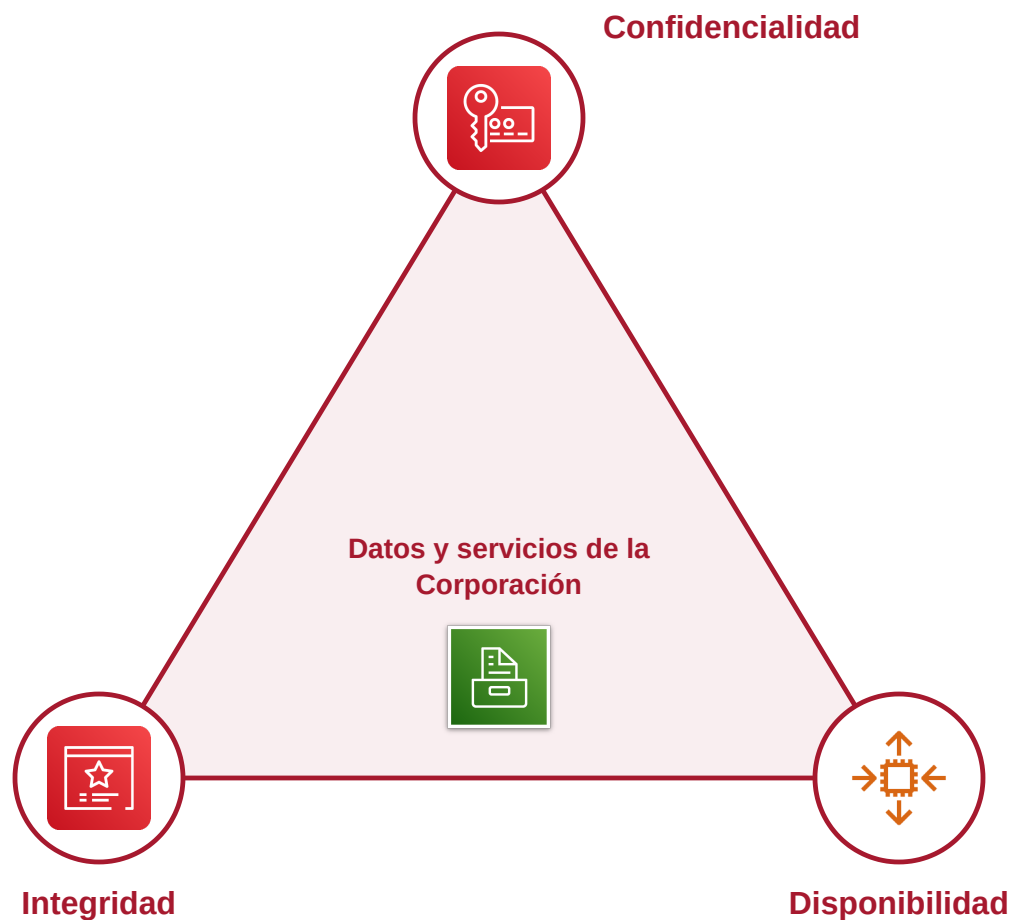
Hoy los reunimos en un marco: defensa en profundidad

Cada capa contiene el daño si la anterior falla. Lo que ya sabes hacer son las primeras capas.

Seguridad no es un producto: es una disciplina de diseño.

La tríada CIA: qué protegemos

Confidencialidad, integridad y disponibilidad: toda decisión de seguridad defiende al menos una.



Confidencialidad

Solo ve el dato quien debe verlo

Amenaza: Filtración de la nómina o de fórmulas de producción

Control: IAM con mínimo privilegio + cifrado

Integridad

El dato no cambia sin dejar rastro

Amenaza: Alguien modifica el valor de una orden de compra

Control: Versionado, firmas y registros de auditoría

Disponibilidad

El sistema responde cuando se necesita

Amenaza: ERP caído en día de despacho o ataque de denegación de servicio

Control: Varias zonas, respaldos y protección DDoS

Corporación Industrial del Caribe: el punto de partida

Hoy todo vive en una red plana en la planta de Barranquilla, con tres riesgos concretos.



Seguridad de la nube y seguridad en la nube

El proveedor asegura la infraestructura; tú aseguras lo que construyes y guardas encima.



Quién asegura qué: de on-premise a SaaS

Cuanto más gestionado es el servicio, más capas asume el proveedor; datos e identidades siempre son tuyos.

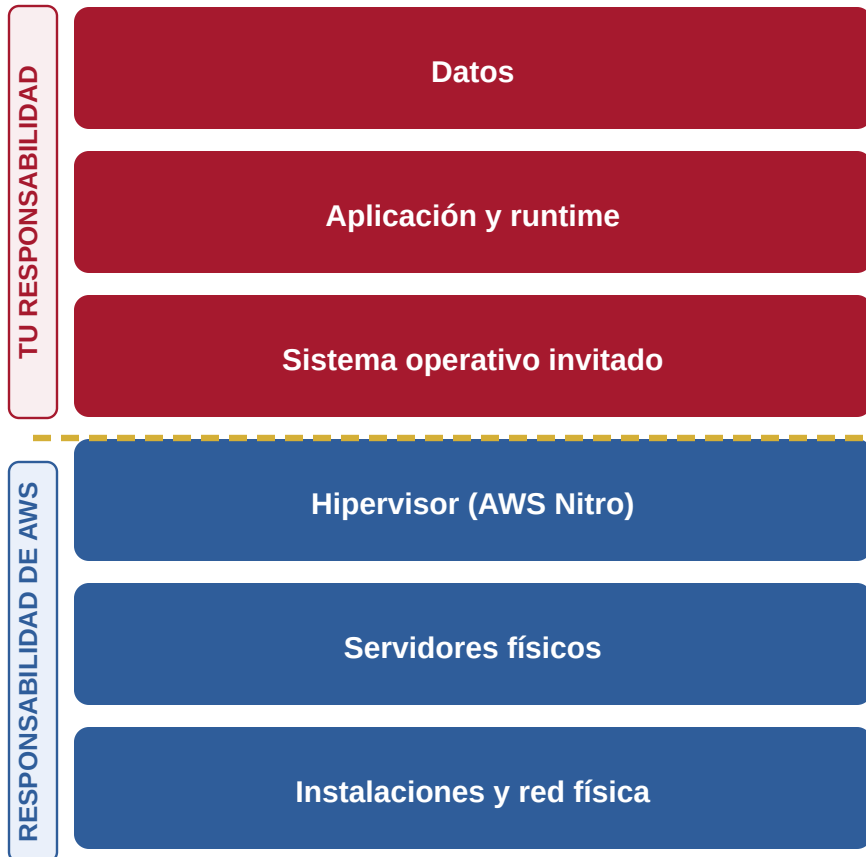
Capa de responsabilidad	 On-premise	 IaaS	 PaaS	 SaaS
Datos y su clasificación	Tú	Tú	Tú	Tú
Cuentas e identidades	Tú	Tú	Tú	Tú
Aplicaciones	Tú	Tú	Tú	Proveedor
Controles de red y firewall	Tú	Tú	Compartido	Proveedor
Sistema operativo y parches	Tú	Tú	Proveedor	Proveedor
Virtualización	Tú	Proveedor	Proveedor	Proveedor
Servidores y almacenamiento físico	Tú	Proveedor	Proveedor	Proveedor
Red física	Tú	Proveedor	Proveedor	Proveedor
Centro de datos (edificio, energía)	Tú	Proveedor	Proveedor	Proveedor

Siempre tuyo en cualquier modelo: datos e identidades.

 Tú  Proveedor  Compartido (según el servicio)

En una instancia EC2 el sistema operativo es tuyo

Con máquinas virtuales el proveedor llega hasta el hipervisor; de ahí hacia arriba, tú.



Tu lista de tareas en IaaS

-  **Parchar el sistema operativo**
Patch Manager automatiza ventanas de parches
-  **Cerrar puertos con Security Groups**
solo lo necesario: 443, y 22 nunca abierto al mundo
-  **Dar un rol IAM a la instancia**
credenciales temporales, sin llaves dentro del servidor
-  **Cifrar los volúmenes EBS**
la clave la gestiona KMS
-  **Tomar copias (snapshots)**
y probar que se pueden restaurar

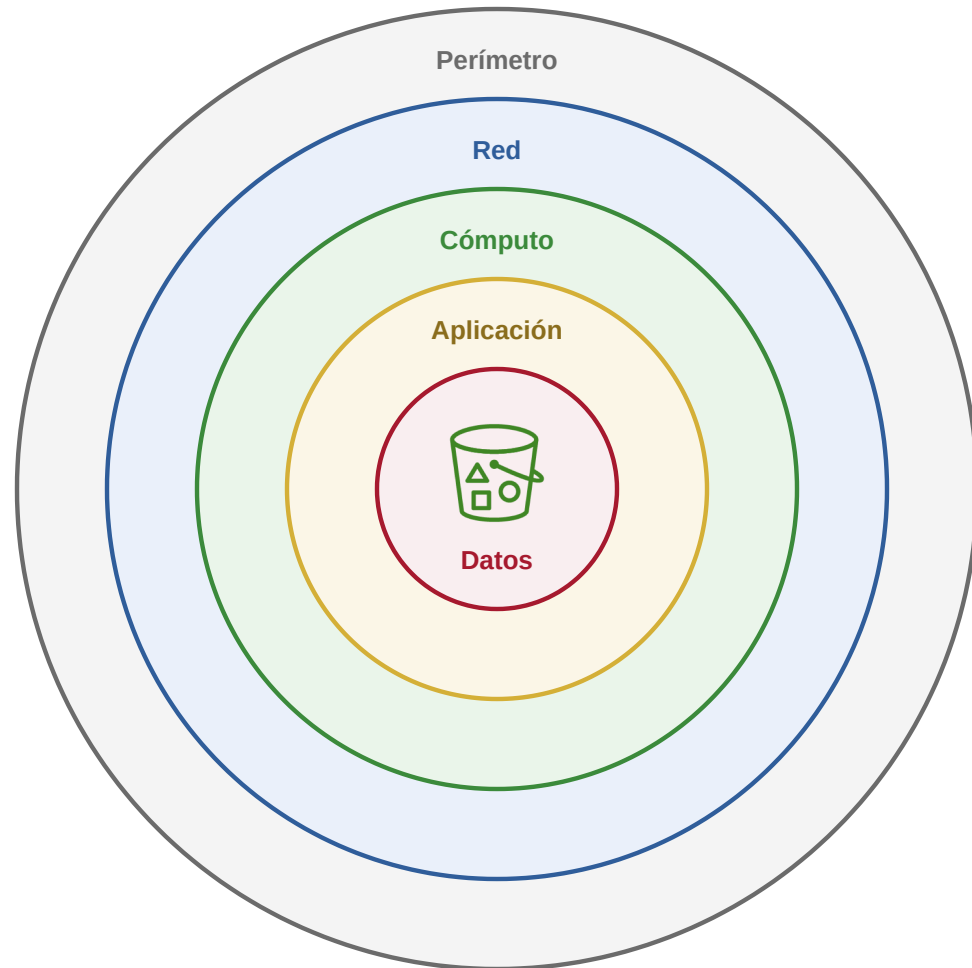
Más gestionado, menos tareas, mismos datos

De EC2 a S3 el proveedor asume más capas; la lista tuya se acorta pero nunca desaparece.



Anillos de defensa: ninguna capa basta sola

Cada capa asume que la exterior ya fue vulnerada y detiene el ataque en la siguiente.



Perímetro

Centros de datos y borde: AWS Shield y WAF



Red

Subredes privadas, Security Groups y NACL



Cómputo

Parches, roles IAM y acceso sin SSH



Aplicación

Validar entradas; secretos fuera del código



Datos

Cifrado en reposo y en tránsito, copias

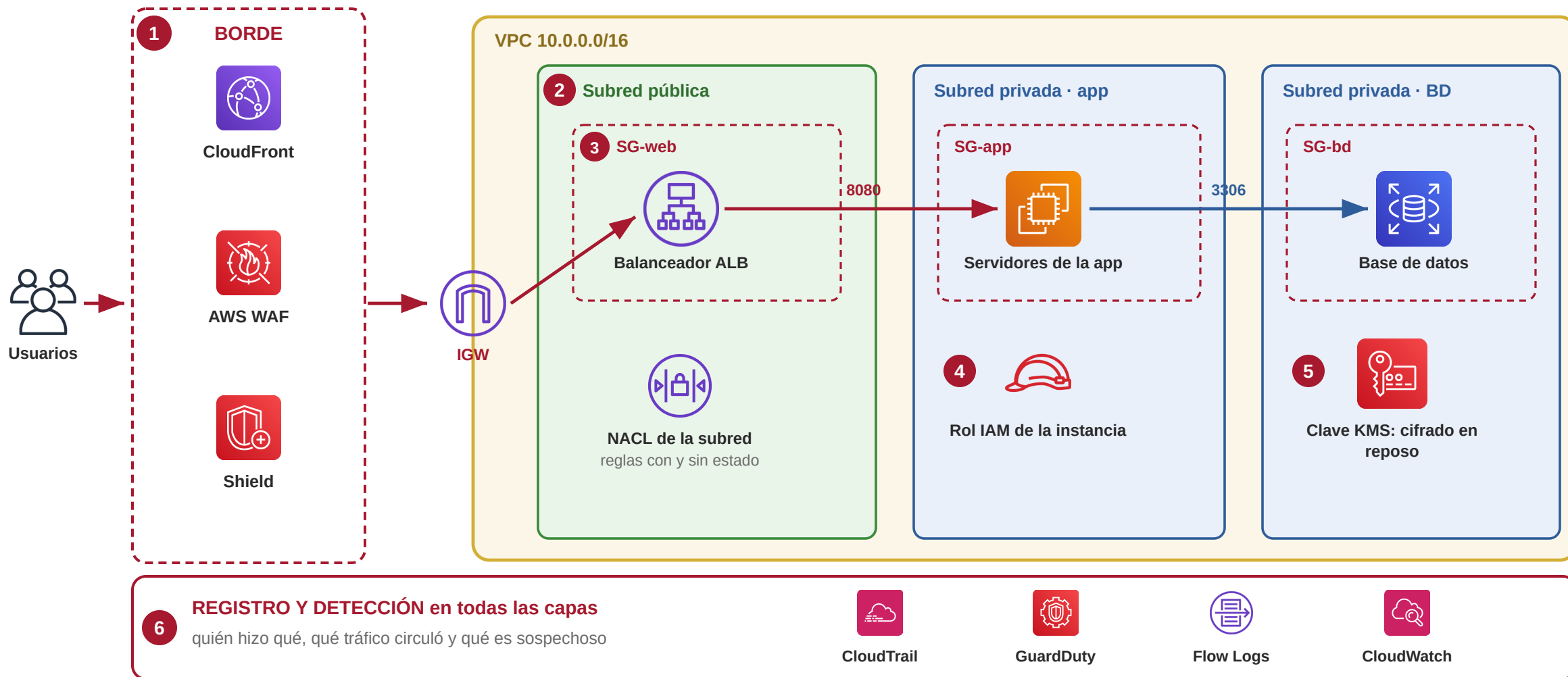


Identidad y registros atraviesan todas las capas

quién accedió y qué hizo, en cada anillo

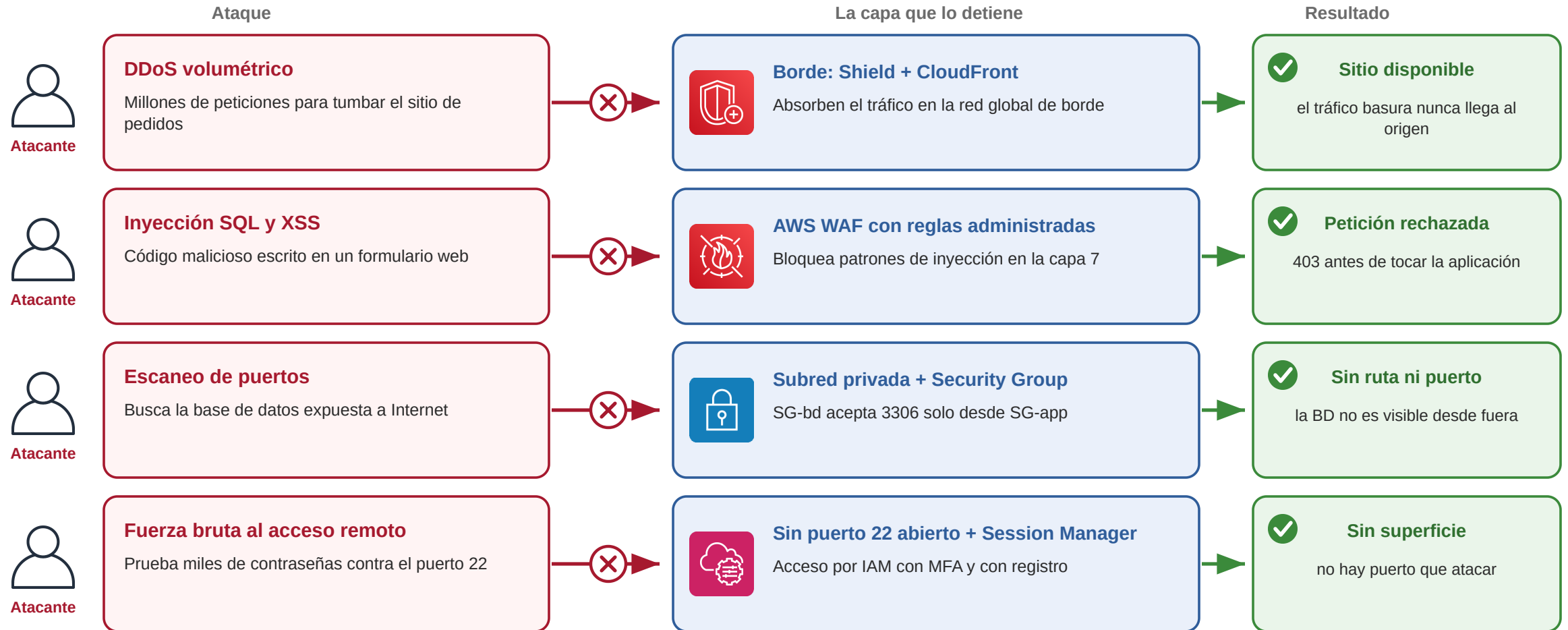
Las capas sobre una VPC real

Seis controles se ven en una sola topología: el atacante debe vencerlos en orden.



Ataques desde Internet y la capa que los detiene

Cada amenaza conocida tiene un control natural; por eso las capas no se repiten, se complementan.



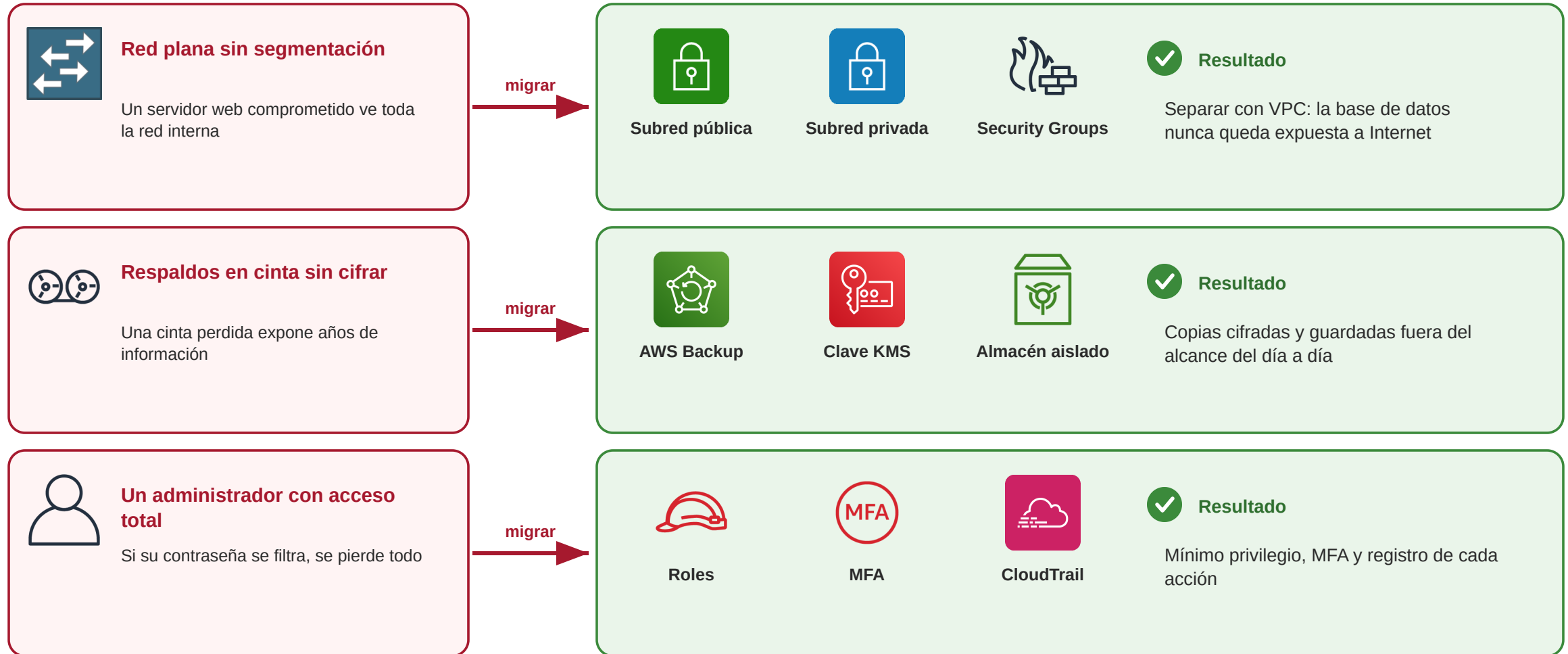
Ataques a identidades y datos: qué capa los detiene

Las amenazas más costosas hoy no rompen la red: usan credenciales, errores de configuración o copias robadas.



Corporación Industrial del Caribe: del riesgo al control

Cada riesgo del punto de partida tiene un control equivalente en la nube.



Lo que queda de la Parte 1

Si recuerdas cuatro ideas, que sean estas; en la Parte 2 protegemos el dato aunque todo lo demás falle.

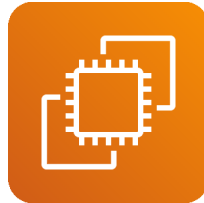
1



Dos mitades

La nube es del proveedor; lo que pones encima es tuyo

2



Una matriz

Más gestionado, menos tareas; datos e identidad siempre tuyos

3



Capas

Perímetro, red, cómputo, aplicación y datos, con identidad transversal

4



Sin atajos

Cada ataque se detiene en una capa distinta

Siguiente: Parte 2 · Cifrado y gestión de claves

Si todas las capas fallan, el dato debe seguir siendo ilegible.



En tránsito



En reposo



Claves



Secretos

Cifrado: en tránsito, en reposo y gestión de claves

Parte 2 de 4 · Unidad 1

Ing. Rodolfo Cañas Cervantes

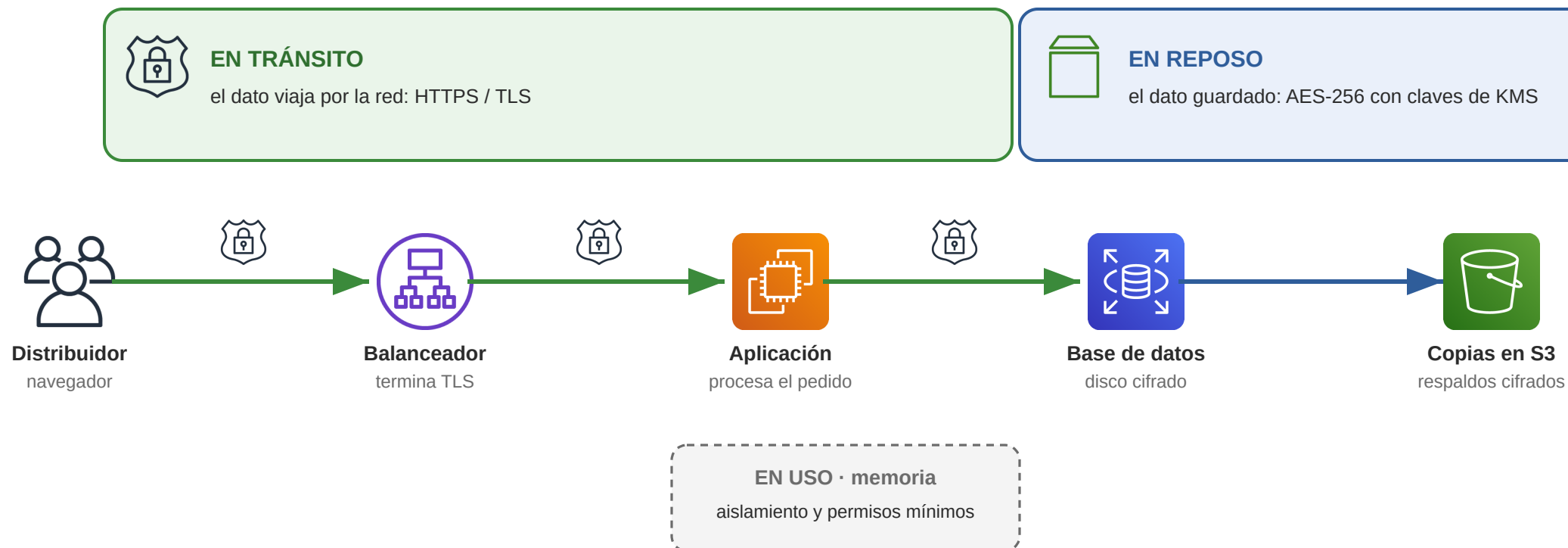
Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

Cómo viaja y cómo se guarda el dato protegido, y quién custodia las llaves y los secretos.

El dato tiene tres momentos, y dos se cifran

En tránsito viaja por la red; en reposo está guardado; en uso está en memoria.



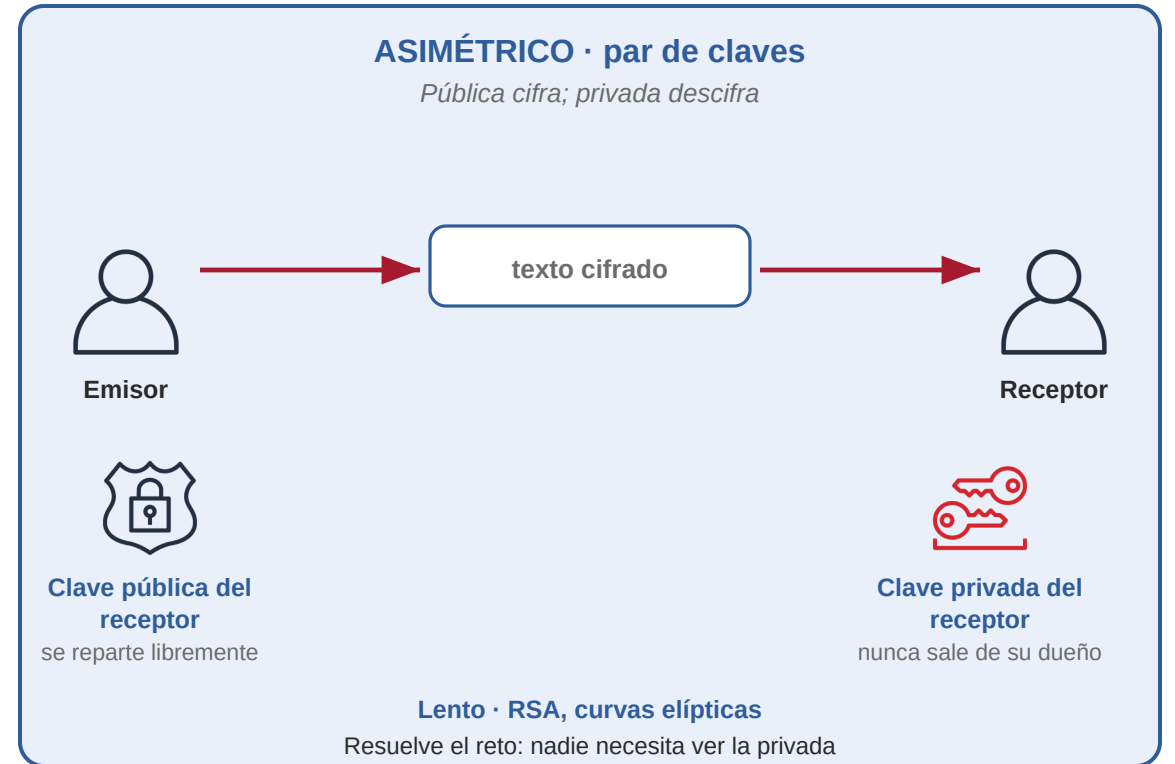
Regla práctica

Cifra siempre en tránsito y en reposo, y hazlo por defecto, no por excepción.

El cifrado no reemplaza al control de acceso: lo complementa cuando las demás capas fallan.

Clave única o par de claves

La simétrica es rápida y cifra los datos; la asimétrica es lenta y permite acordar claves sin verse.

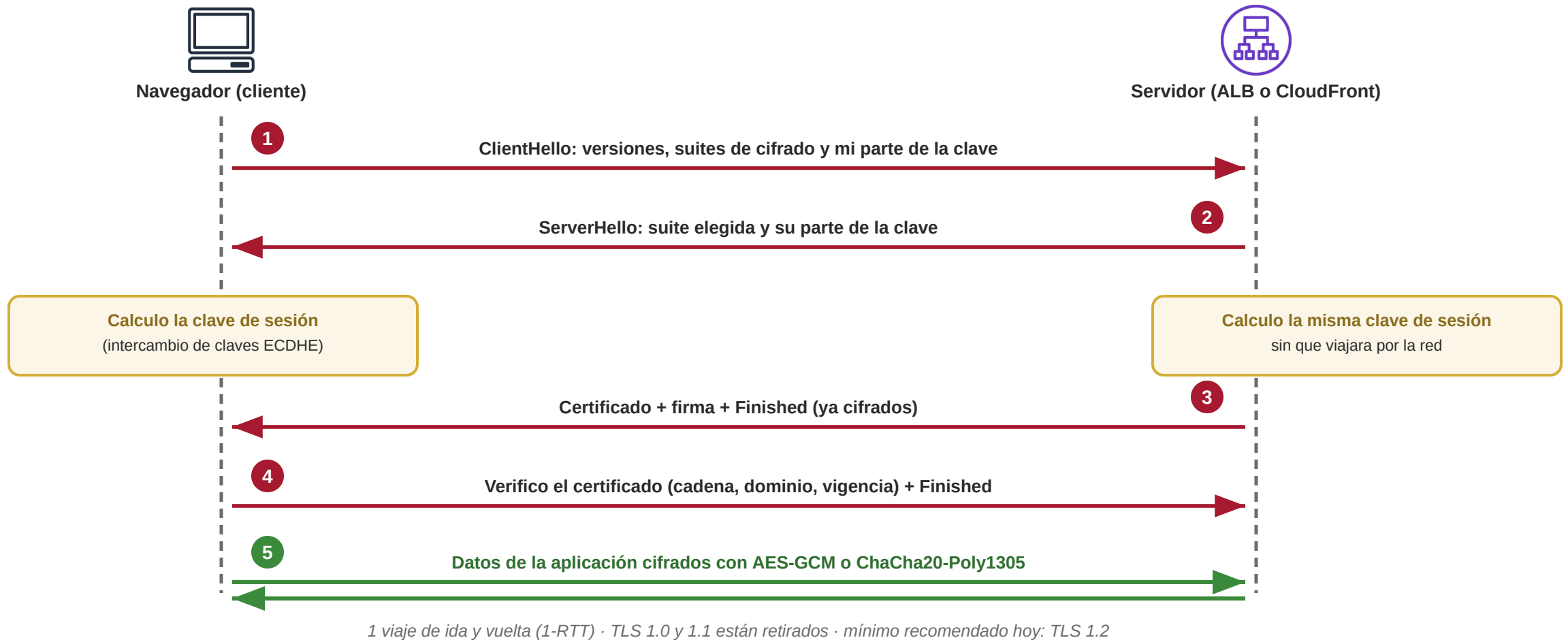


En la práctica se combinan (TLS, KMS): lo asimétrico acuerda la clave, lo simétrico cifra los datos

Asimétrico para acordar y firmar · simétrico para cifrar volúmenes grandes

El apretón de manos TLS 1.3, paso a paso

En un solo viaje de ida y vuelta, cliente y servidor acuerdan una clave de sesión que nadie más conoce.



Certificados: la cadena de confianza

El navegador confía en el sitio porque una autoridad que ya conoce firmó su certificado.



El navegador comprueba

- ✓ La firma llega a una raíz de confianza
- ✓ El dominio coincide con el sitio visitado
- ✓ El certificado no está vencido
- ✓ No ha sido revocado

✗ **Si una comprobación falla, el navegador muestra la advertencia**
y la conexión no debe continuar: nunca ignores esa pantalla en producción.

Dónde se obtienen

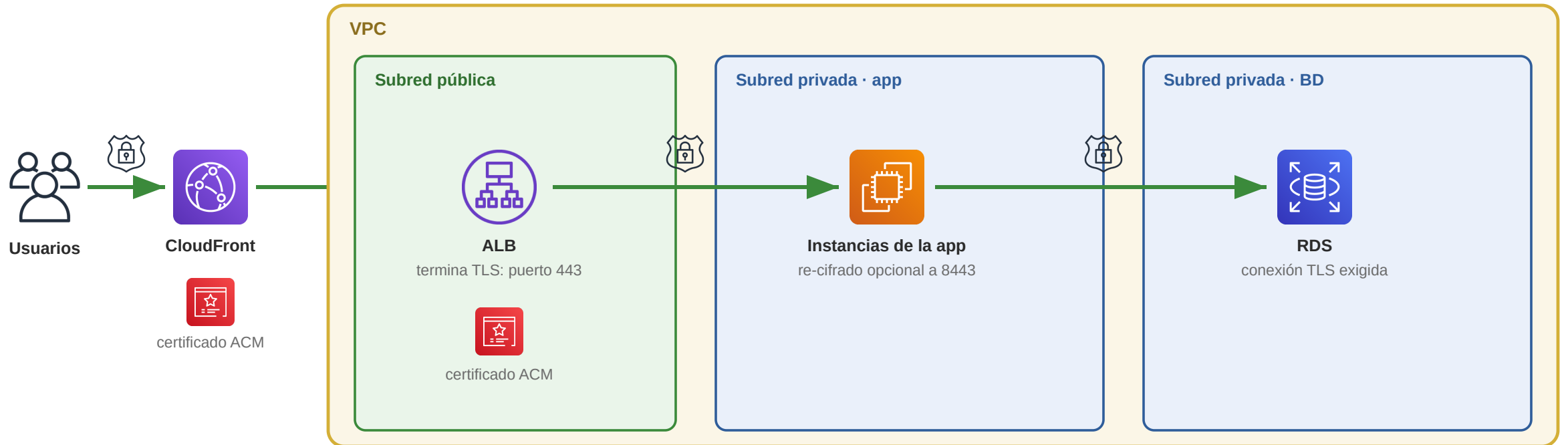
 **AWS Certificate Manager**
públicos para ALB y CloudFront, renovación automática

 **Let's Encrypt**
autoridad gratuita con emisión automatizada

Vigencias cortas: automatiza la renovación

TLS en una arquitectura AWS: dónde termina

El cifrado se extiende hasta la base de datos si lo configuras en cada tramo.



1 Redirigir HTTP a HTTPS

el puerto 80 solo responde con redirección al 443

2 TLS 1.2 como mínimo

y 1.3 donde el cliente lo permita; política de seguridad del ALB

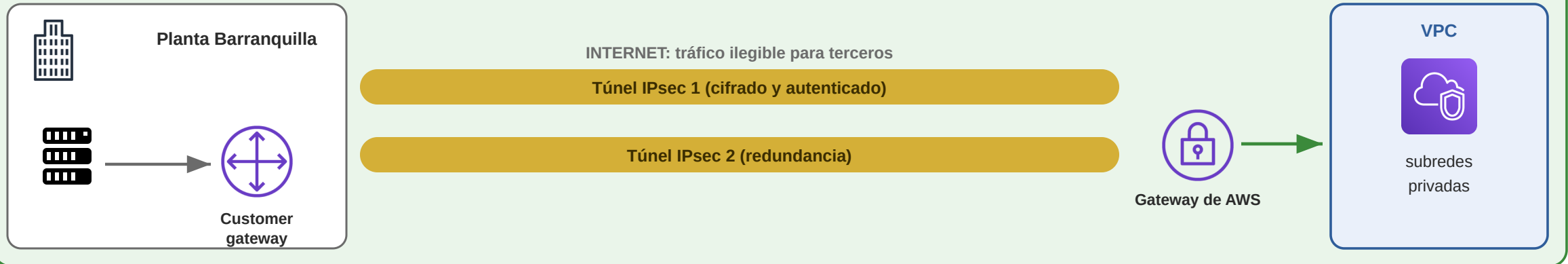
3 S3: negar transporte inseguro

condición `aws:SecureTransport` igual a `false` en la política del bucket

De la planta a la nube: VPN IPsec

Internet no es de confianza: el túnel IPsec cifra todo lo que cruza entre la planta y la VPC.

Opción 1 · VPN de sitio a sitio sobre Internet



Opción 2 · Direct Connect: enlace dedicado, privado pero no cifrado por defecto



AES-256: de texto legible a ilegible

El mismo algoritmo protege discos, buckets y copias; quien robe el medio no obtiene información.



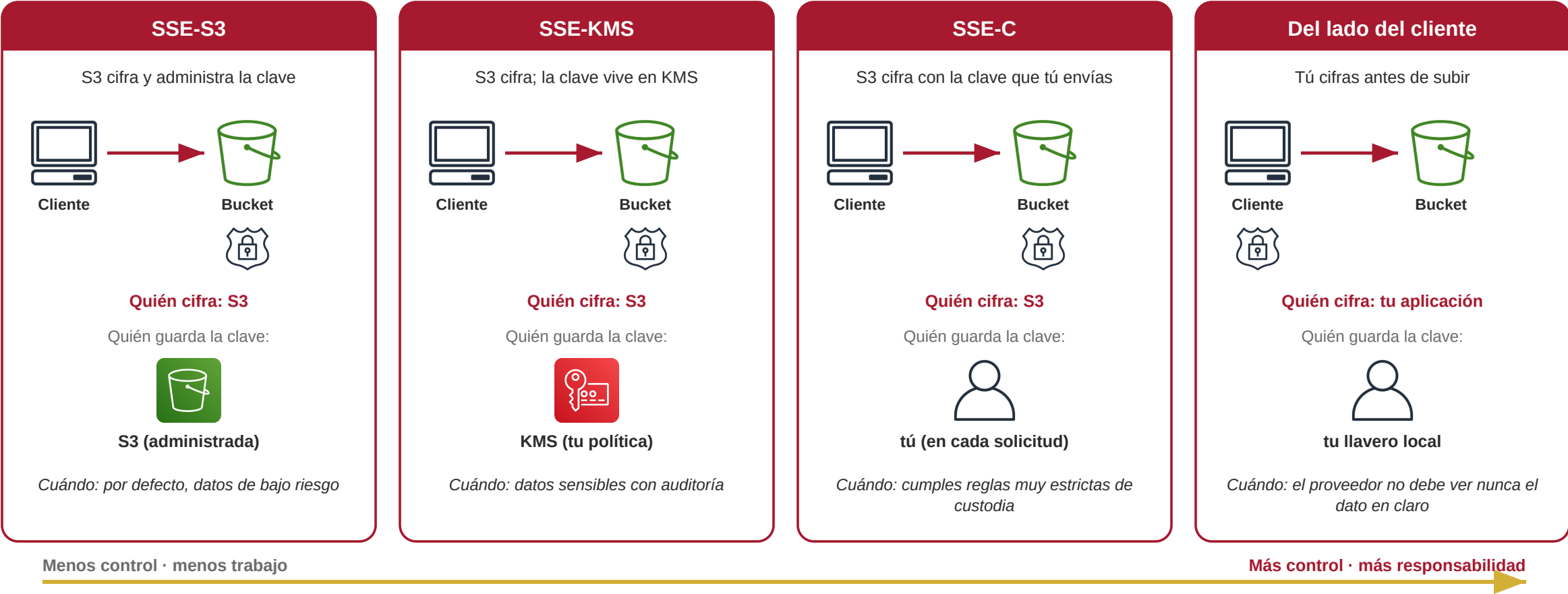
Dónde lo aplica AWS



Transparente para la aplicación: se cifra al escribir y se descifra al leer, solo para identidades autorizadas.

Cuatro formas de cifrar en S3

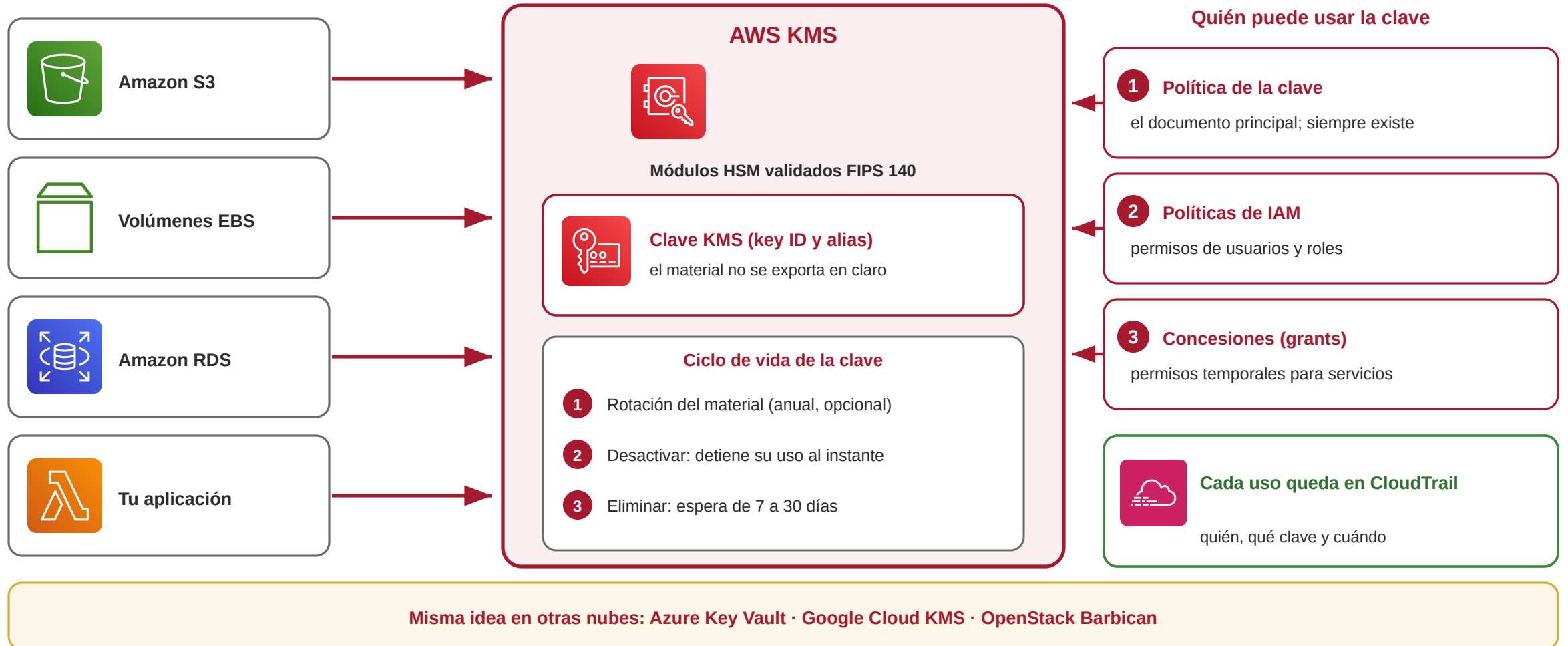
La diferencia no está en el algoritmo sino en quién cifra y quién guarda la clave.



La opción habitual en datos corporativos: SSE-KMS con clave administrada por el cliente

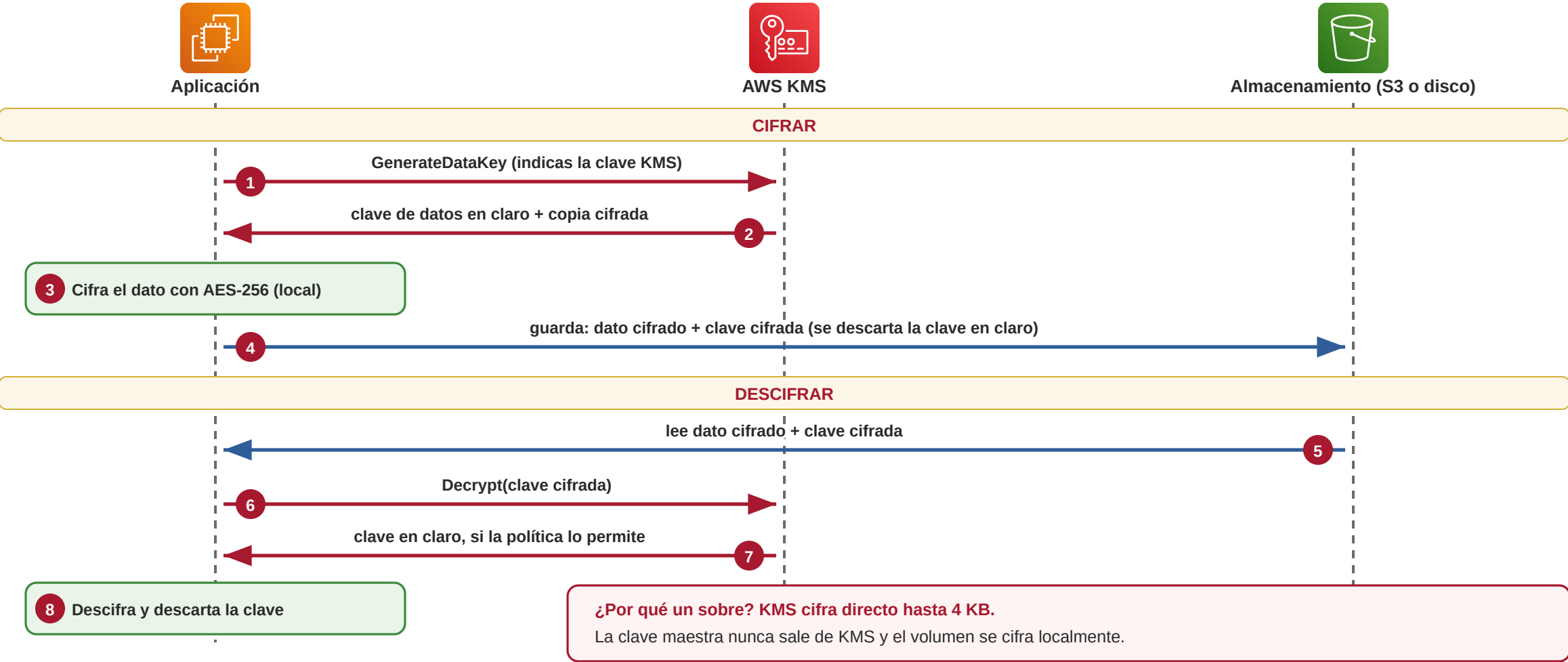
KMS: la caja fuerte de las claves

La clave nunca sale de KMS sin protección: los servicios le piden operar, no se la llevan.



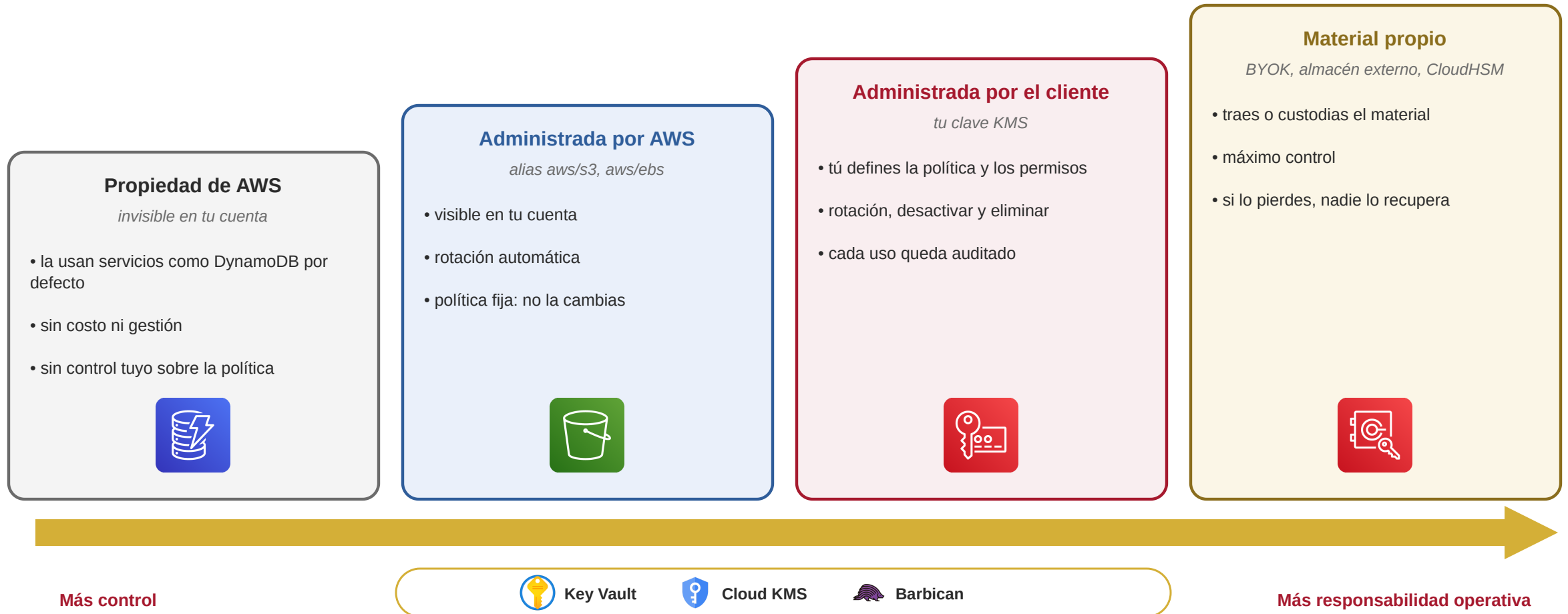
Cifrado de sobre (envelope encryption)

Una clave de datos cifra el dato; la clave de KMS cifra esa clave de datos: así crece sin cargar a KMS.



Claves del proveedor o claves del cliente

Más control sobre la clave significa más responsabilidad para ti: elige según la sensibilidad del dato.



Secretos: contraseñas y llaves fuera del código

Un secreto en el repositorio es un secreto publicado; se entrega en tiempo de ejecución y se rota.

Mal: el secreto va en el código



repositorio Git

visible para todos los que lo clonan

```
# config.py
DB_HOST = "bd.interna"
DB_USER = "admin"
DB_PASSWORD = "Caribe2026!"
AWS_SECRET_KEY = "wJal..."
```



Consecuencias

- Queda en el historial para siempre
- Se copia a cada portátil y servidor
- Nadie sabe quién la usó ni cuándo
- Cambiarla exige redespargar

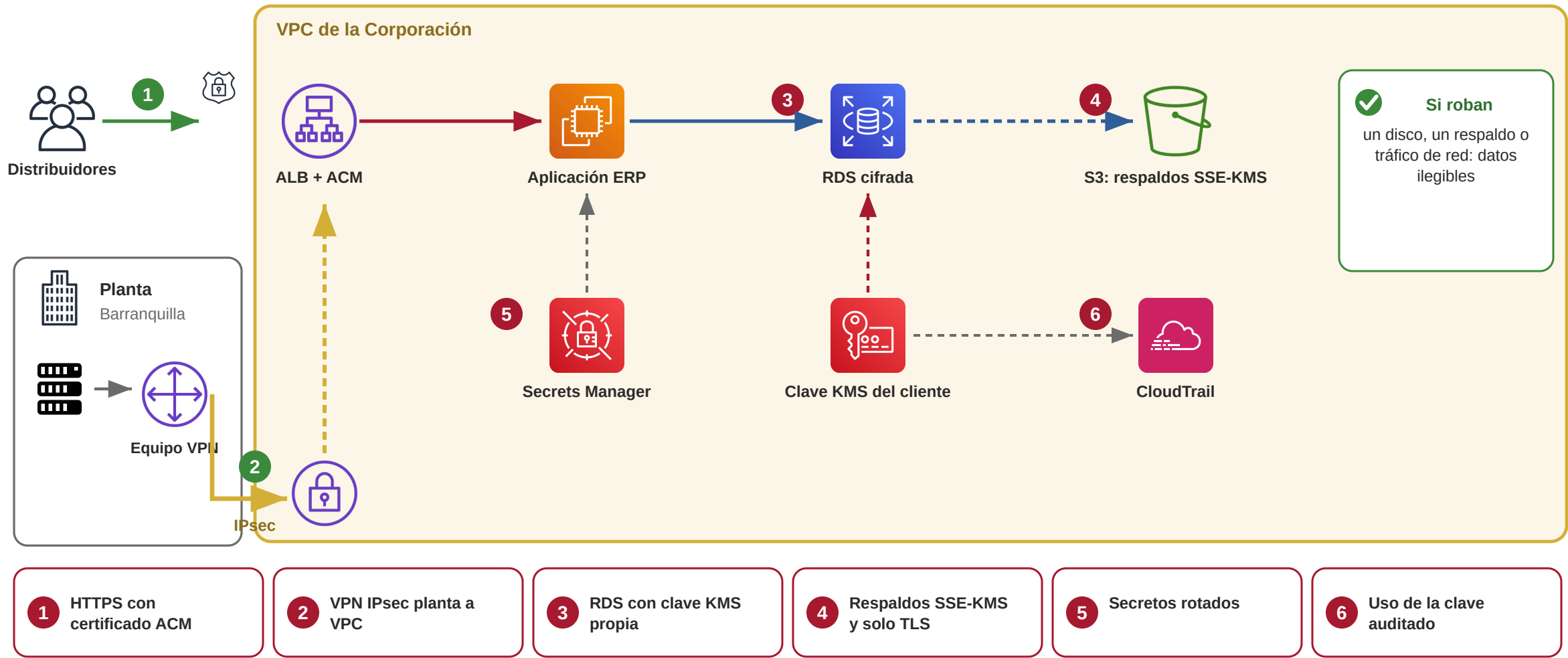
Bien: el secreto se entrega en tiempo de ejecución



Equivalentes: HashiCorp Vault · Azure Key Vault · Google Secret Manager. Parameter Store guarda configuración; no es para rotar secretos.

Corporación Industrial del Caribe: todo cifrado

Seis decisiones de cifrado cubren el viaje del dato, su reposo y las llaves de la migración.



Lo que queda de la Parte 2

Cifra el dato en cada tramo, cuida las llaves como un tesoro y saca los secretos del código.

1



En tránsito

TLS en cada tramo, certificados y VPN IPsec hacia la planta

2



En reposo

AES-256 en discos, buckets y copias

3



Claves

KMS, cifrado de sobre y claves del cliente

4



Secretos

Fuera del código, con rol y rotación automática

Siguiente: Parte 3 · Visibilidad y protección

Cifrar no basta si no te enteras de lo que ocurre: registrar, alertar, detectar y filtrar.



Auditoría



Detección



WAF y DDoS



Postura

Visibilidad y protección: auditar, detectar y filtrar

Parte 3 de 4 · Unidad 1

Ing. Rodolfo Cañas Cervantes

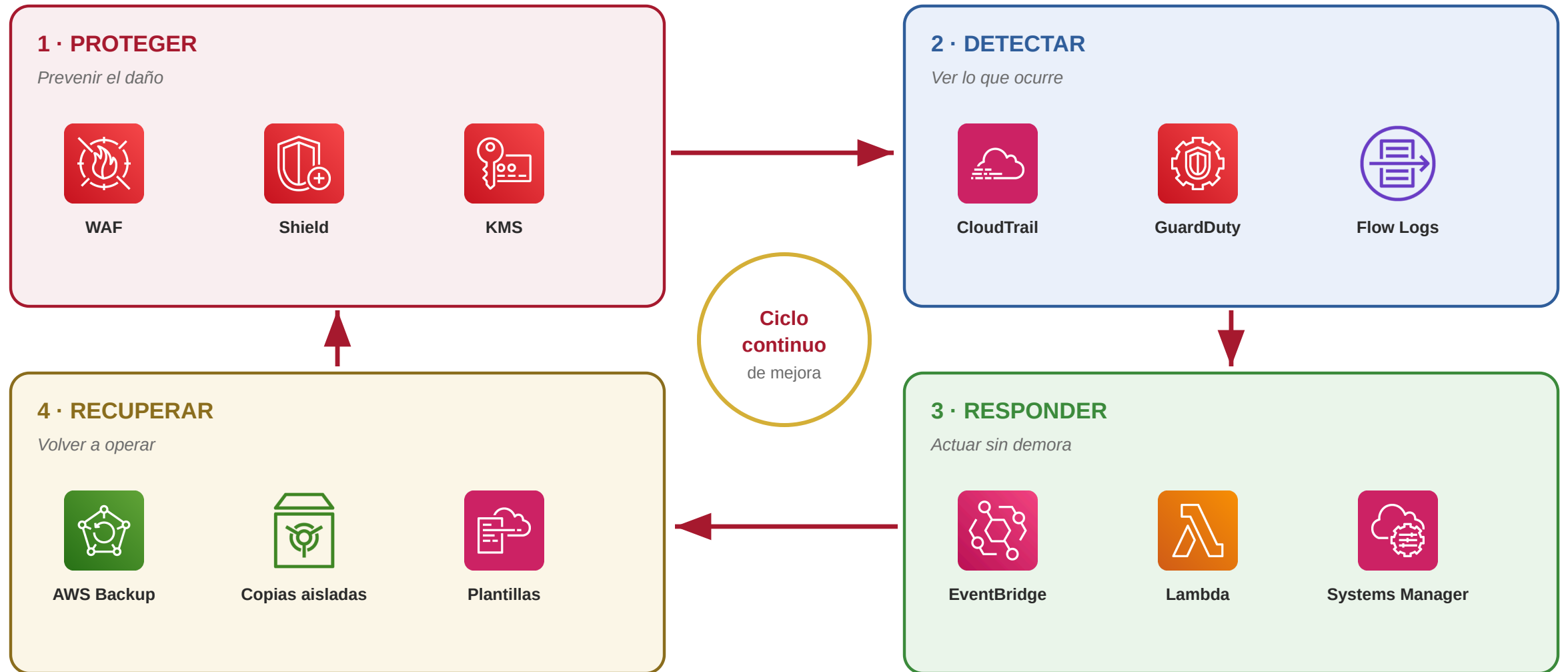
Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

Registro de auditoría, alertas, detección de amenazas, WAF, DDoS y postura de seguridad centralizada.

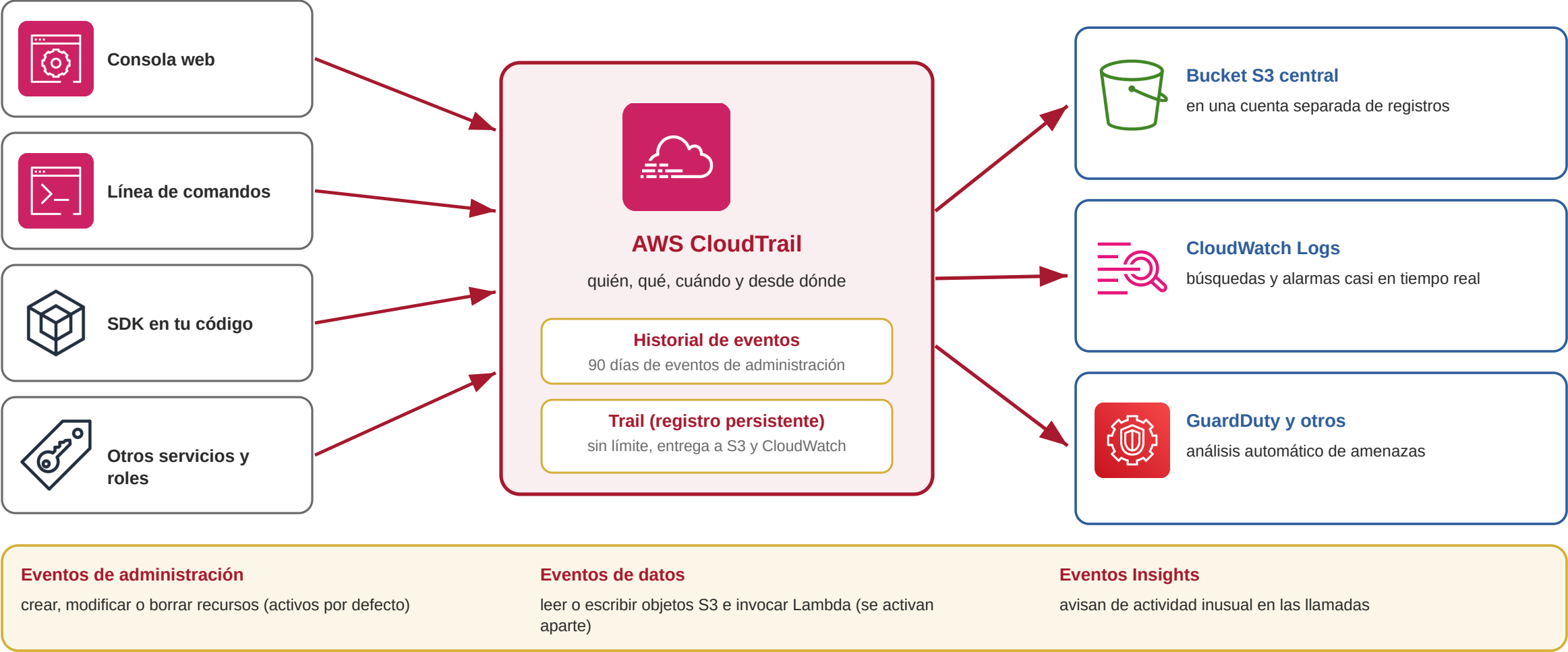
Proteger, detectar, responder y recuperar

No puedes proteger lo que no ves: la seguridad es un ciclo continuo, no una instalación única.



CloudTrail: el libro de actas de tu cuenta

Cada llamada a la API de AWS queda registrada: consola, línea de comandos, SDK y otros servicios.



Anatomía de un evento: ¿quién apagó el servidor?

Un solo registro responde las preguntas de una investigación: quién, qué, cuándo, desde dónde y sobre qué.

Evento de CloudTrail (simplificado)

```
{
  "eventTime": "2026-09-01T09:42:17Z",
  "eventSource": "ec2.amazonaws.com",
  "eventName": "TerminateInstances",
  "userIdentity": {
    "type": "IAMUser",
    "userName": "operador-planta" },
  "sourceIPAddress": "203.0.113.25",
  "awsRegion": "us-east-1",
  "requestParameters": { "instanceId": "i-0abc1234" }
}
```

1

2

3

4

5

6

Qué responde cada campo

- 1 CUÁNDO

la hora exacta del evento
- 2 QUÉ SERVICIO

y qué acción pidió
- 3 QUÉ HIZO

apagar instancias
- 4 QUIÉN

usuario o rol que actuó
- 5 DESDE DÓNDE

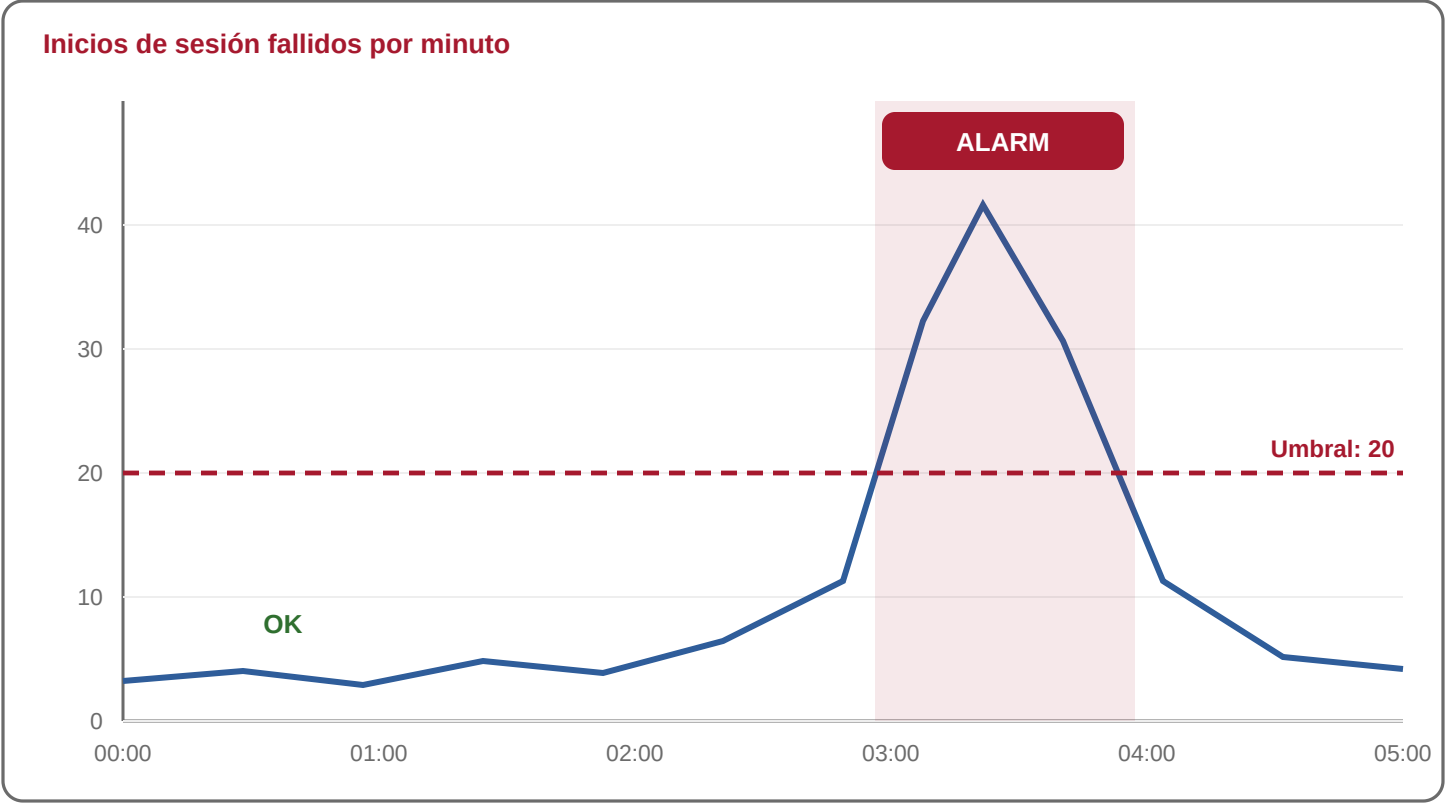
dirección IP de origen
- 6 SOBRE QUÉ

el recurso afectado
- ! **Siguiente paso de la investigación**

Filtra por userName y revisa qué más hizo en esa hora; si la cuenta fue comprometida, desactiva sus credenciales.

CloudWatch: de la métrica a la alarma

Una métrica que cruza un umbral dispara una alarma, y la alarma avisa a las personas correctas.



¿De dónde sale la métrica? De un filtro sobre los registros de CloudTrail en CloudWatch Logs

Ejemplo recomendado: avisar cada vez que se use la cuenta raíz.



Alarma

OK, ALARM o datos insuficientes



Tema de SNS

publica el mensaje de aviso



Equipo de seguridad

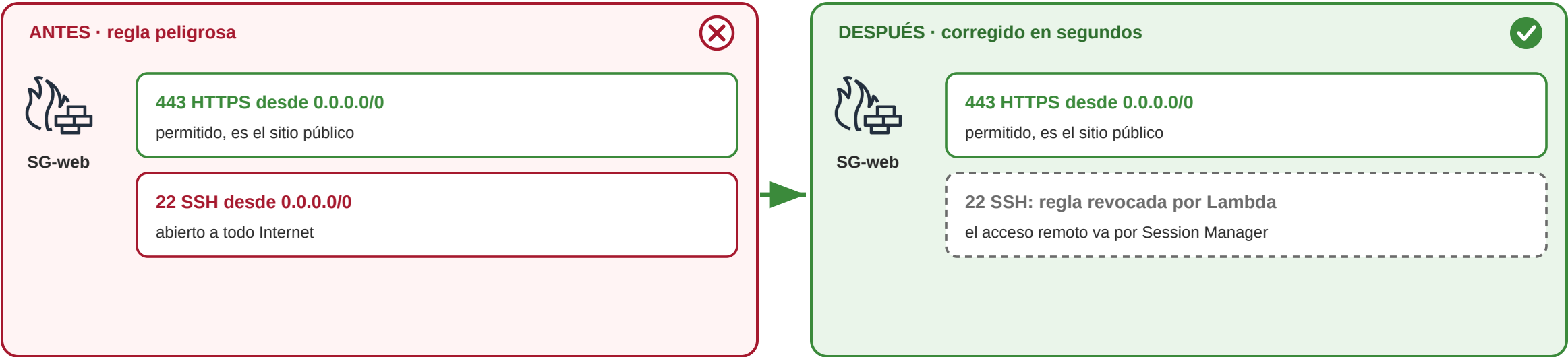
correo, SMS o chat

De la alerta a la acción: EventBridge y Lambda

Una regla puede avisar y corregir en segundos, sin esperar a que alguien despierte.

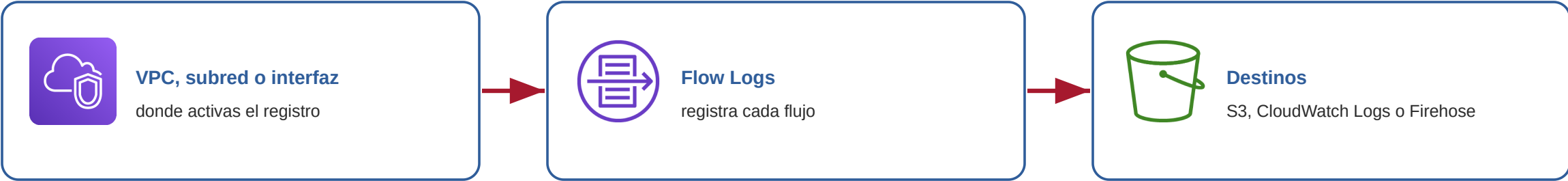


El Security Group, antes y después



VPC Flow Logs: quién habló con quién

Registran metadatos de cada conexión aceptada o rechazada, útiles para investigar y validar reglas.



Un registro de ejemplo, campo por campo

versión 2	cuenta 123456789012	interfaz eni-0a1b2c	origen 198.51.100.7	destino 10.0.1.25	puerto origen 44213
puerto destino 22	protocolo 6 (TCP)	paquetes 3	bytes 180	acción REJECT	estado OK

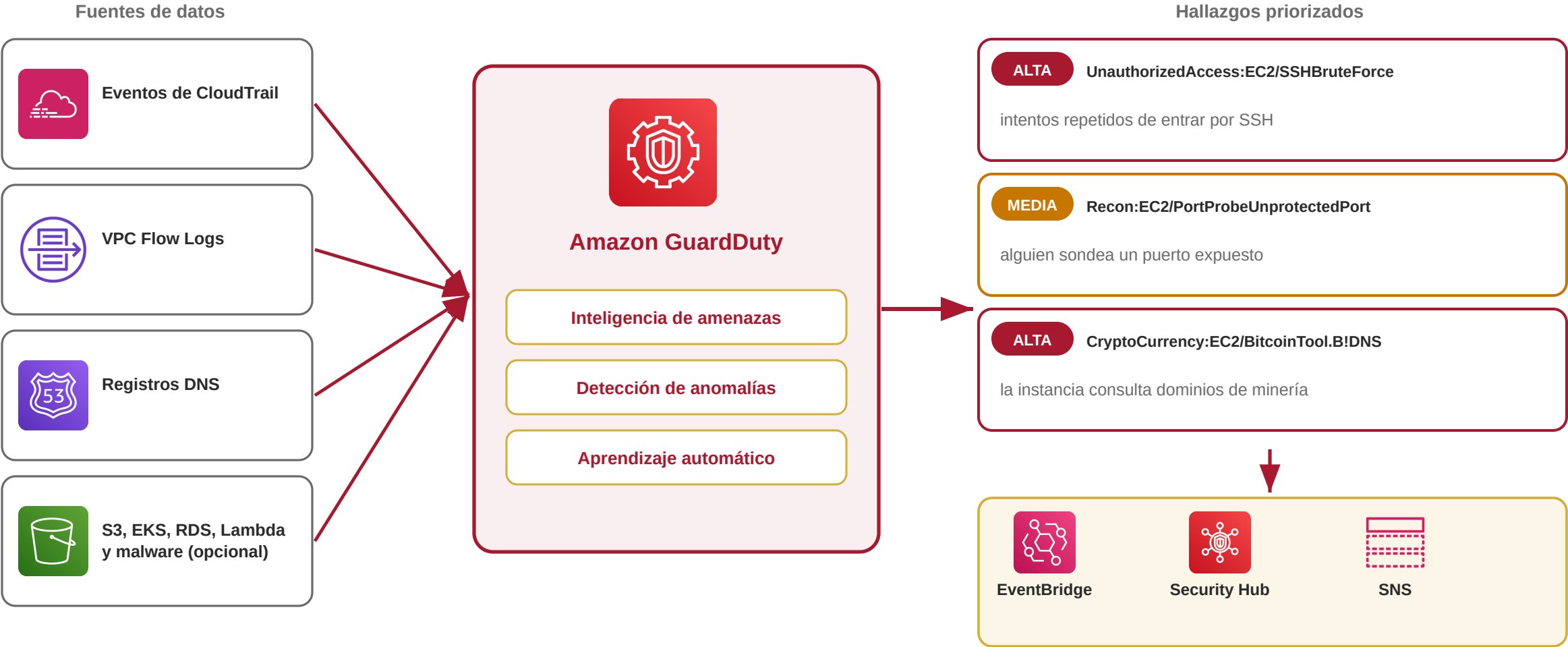


Lectura: una IP externa intentó entrar por SSH (puerto 22) y el Security Group la rechazó.

Registra metadatos, no el contenido de los paquetes. Sirve para análisis posterior y alimenta a GuardDuty.

GuardDuty: un analista que nunca duerme

Analiza tus registros con inteligencia de amenazas y aprendizaje automático, y te entrega hallazgos priorizados.



Otros vigilantes: Inspector, Macie, Config y Access Analyzer

Cada servicio responde una pregunta distinta sobre tu superficie de riesgo.



Amazon Inspector

¿Mis cargas tienen vulnerabilidades conocidas?

EC2, imágenes de contenedores y funciones Lambda, con prioridad por riesgo

Ejemplo: un paquete del servidor web con una falla publicada.



Amazon Macie

¿Hay datos personales donde no deberían?

Examina buckets de S3 y detecta cédulas, tarjetas y credenciales

Ejemplo: una hoja de nómina en un bucket de pruebas.

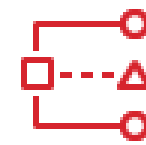


AWS Config

¿Mis recursos cumplen las reglas?

Guarda el historial de configuración y evalúa reglas de cumplimiento

Ejemplo: un volumen EBS sin cifrar.



IAM Access Analyzer

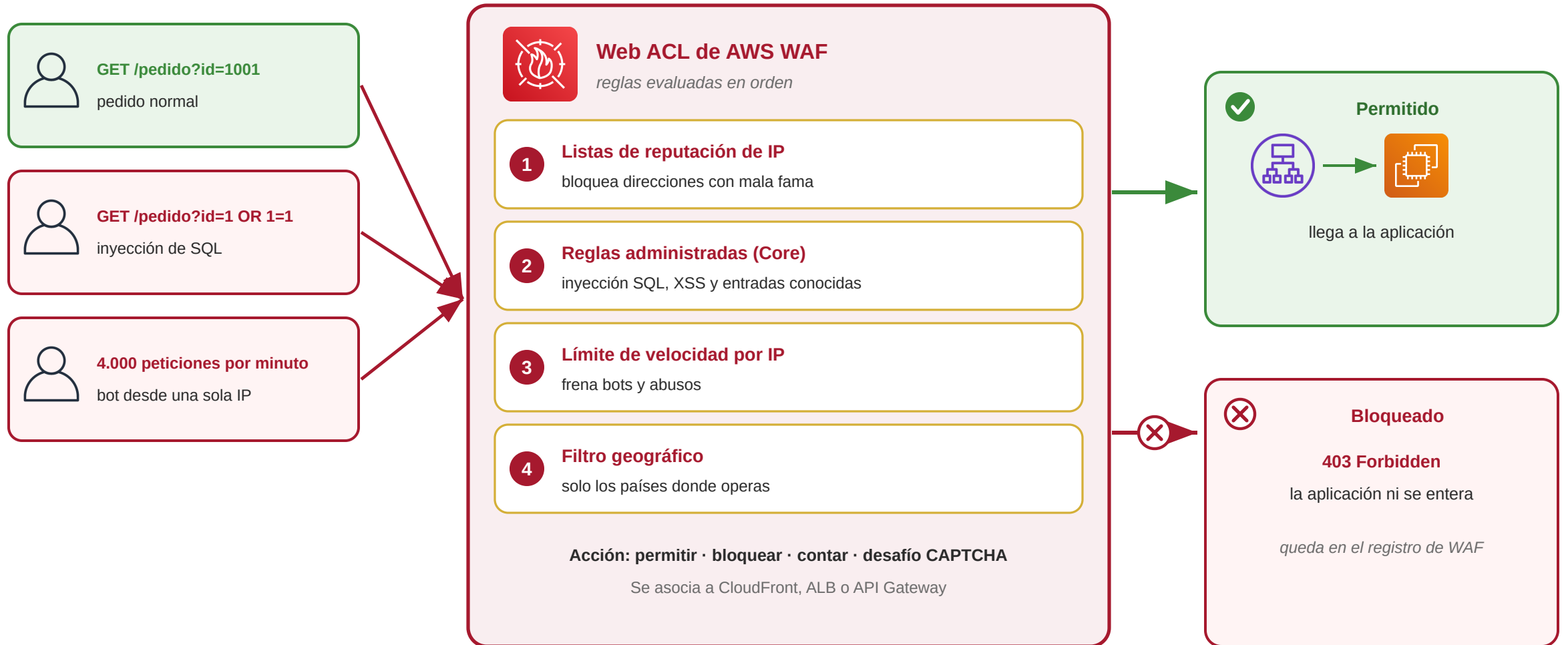
¿Quién externo puede acceder a mis recursos?

Detecta recursos compartidos fuera de tu cuenta u organización

Ejemplo: un bucket compartido con una cuenta desconocida.

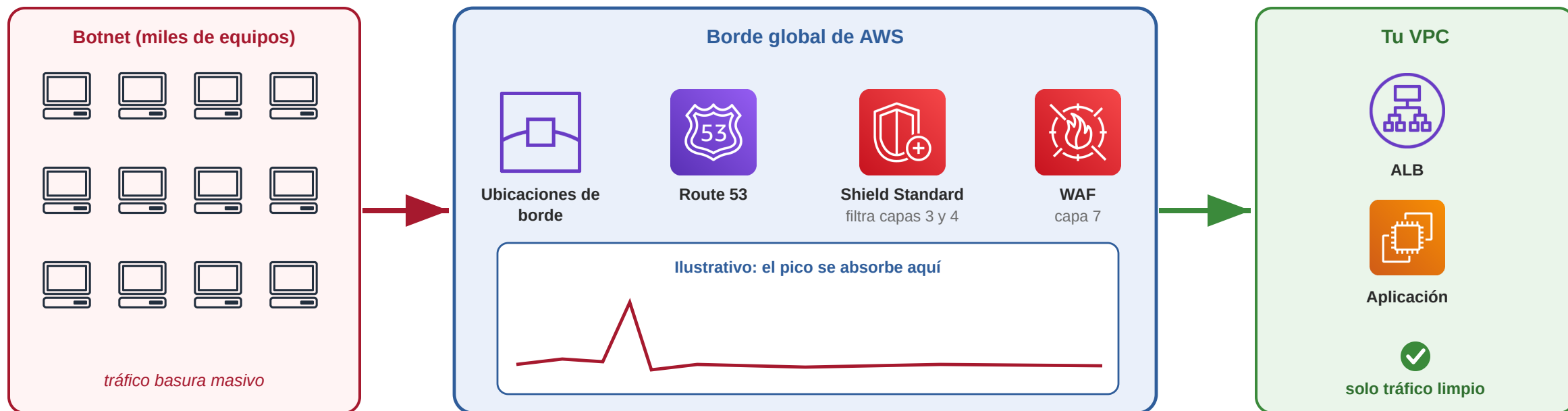
AWS WAF: el filtro de la capa de aplicación

Inspecciona cada petición HTTP y bloquea la inyección, los bots y los abusos antes de tocar tu aplicación.



DDoS: absorber el ataque antes del origen

La red global de borde reparte y filtra la avalancha; tu VPC recibe solo tráfico limpio.



Shield Standard

incluido en todas las cuentas

- ✓ Protección automática contra ataques comunes de red y transporte
- ✓ Sin costo adicional ni configuración
- ✓ Mejor aún detrás de CloudFront y Route 53

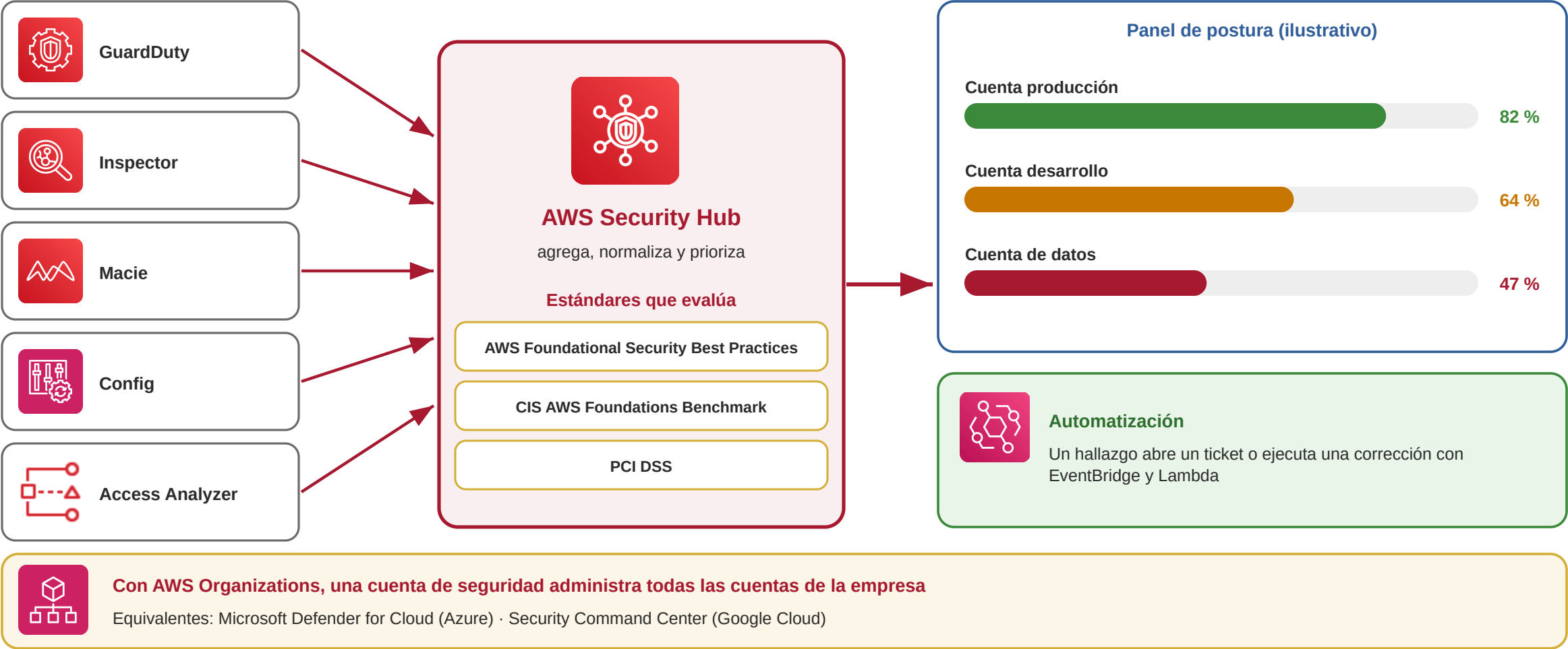
Shield Advanced

suscripción de pago

- ✓ Detección y mitigación más finas, y visibilidad de ataques
- ✓ Respuesta del equipo especializado de AWS (SRT)
- ✓ Protección de costos ante picos causados por el ataque

Security Hub: un solo tablero de seguridad

Reúne los hallazgos de todos los servicios y cuentas y los mide contra estándares reconocidos.



El pilar de seguridad de Well-Architected

El marco de seis pilares dedica siete áreas de buenas prácticas a la seguridad; hoy recorrimos casi todas.



Las siete áreas del pilar de seguridad



Corporación Industrial del Caribe: una madrugada con alerta

La visibilidad convierte un ataque nocturno en un incidente contenido en minutos.



Cómo se organiza en varias cuentas



Lo que queda de la Parte 3

Registrar, alertar, detectar y filtrar: la seguridad que no se ve no se puede defender.

1



Registrar

CloudTrail en una cuenta aparte;
Flow Logs para la red

2



Alertar y responder

Alarmas, EventBridge y Lambda para
corregir en segundos

3



Detectar

GuardDuty, Inspector, Macie, Config
y Access Analyzer

4



Filtrar y centralizar

WAF, Shield y Security Hub con
estándares

Siguiente: Parte 4 · Cumplimiento y cierre de la Unidad 1

Los auditores y la ley preguntan lo mismo: ¿puedes demostrarlo?



ISO 27001, SOC 2



PCI DSS



Ley 1581 y SIC



Región y datos

Cumplimiento: marcos, ley colombiana y datos

Parte 4 de 4 · Unidad 1

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 5 · Periodo 2026-2 · Barranquilla, Colombia

ISO 27001, SOC 2, PCI DSS, la Ley 1581 de 2012, la elección de región y el cierre de la Unidad 1.

Cumplir no es lo mismo que estar seguro

Hay reglas obligatorias, estándares voluntarios y contratos; las tres cosas se prueban con evidencia.

Marcos contractuales y de auditoría

SOC 2 · PCI DSS

los piden clientes, bancos y marcas de tarjetas

Estándares y certificaciones voluntarios

ISO/IEC 27001 · 27017 · 27018

demuestran un sistema de gestión

Leyes y regulación obligatorias

Ley 1581 de 2012 · Ley 1273 de 2009

su incumplimiento tiene sanciones

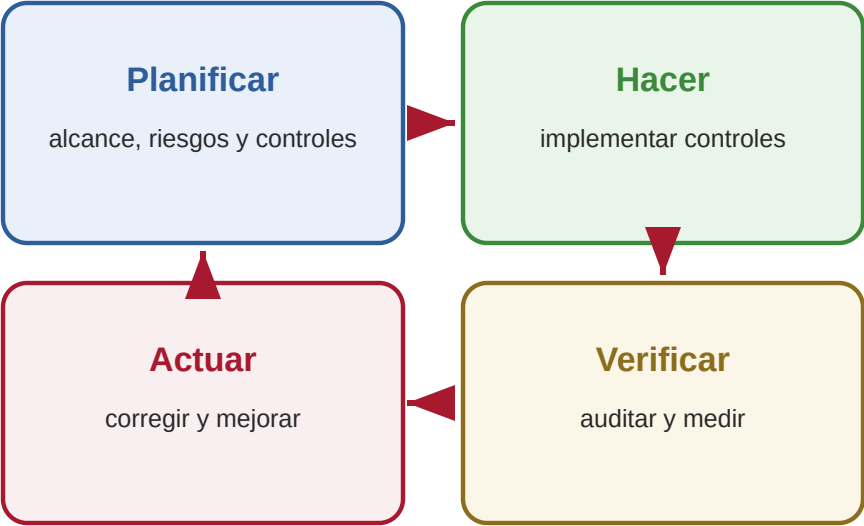


La visibilidad de la Parte 3 es la base

CloudTrail, Config y Security Hub producen la evidencia que piden los auditores.

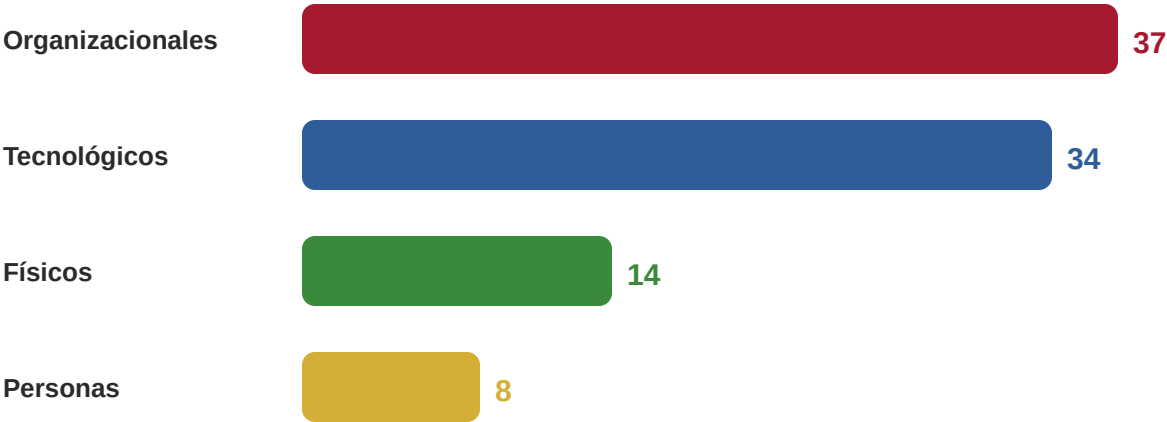
ISO/IEC 27001: un sistema de gestión de seguridad

Certifica que gestionas la seguridad con un ciclo de mejora continua y 93 controles de referencia.



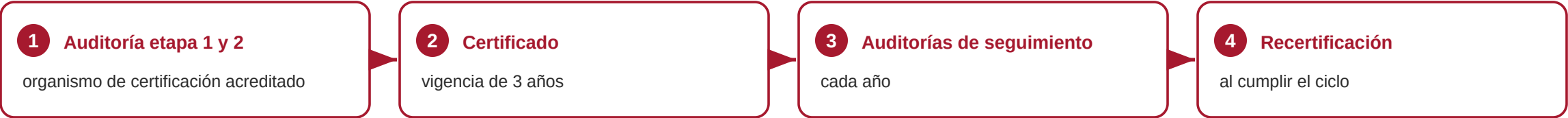
Ciclo PDCA de mejora continua

Anexo A: 93 controles en 4 temas



Con 93 controles en total (versión 2022)

Camino de certificación



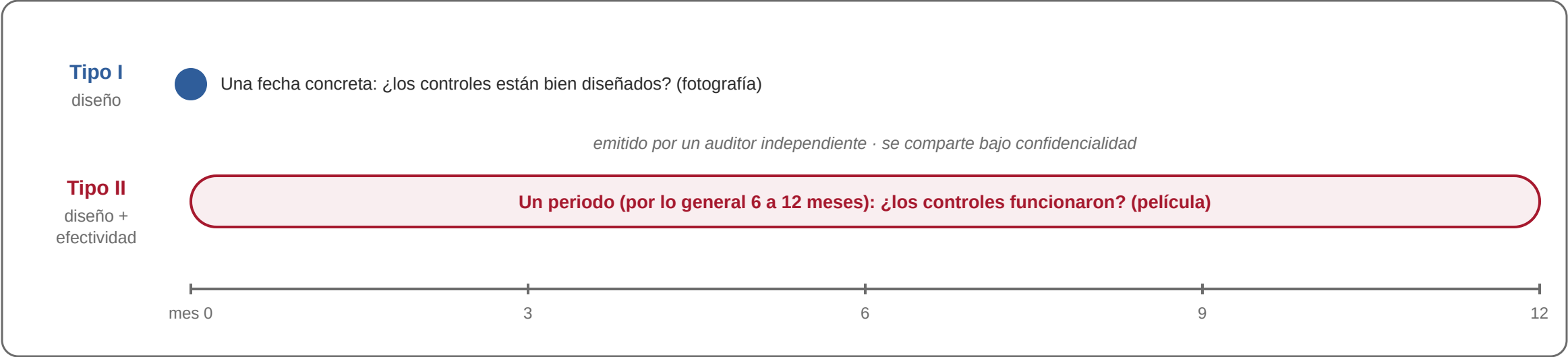
En la nube: ISO/IEC 27017 (controles específicos de nube) · ISO/IEC 27018 (datos personales en nubes públicas)

SOC 2: confianza demostrada por un auditor externo

Un contador público independiente evalúa tus controles frente a cinco criterios de servicio de confianza.



Tipo I frente a tipo II



PCI DSS: si manejas tarjetas, doce requisitos

Es un estándar contractual de las marcas de tarjetas; aplica a quien almacena, procesa o transmite datos de cuenta.



Versión vigente: PCI DSS v4.0.1 · los íconos marcan requisitos que ya cubres con servicios vistos hoy

Qué certifica el proveedor y qué certificas tú

El proveedor cubre lo que opera; tu carga de trabajo debe demostrar lo que tú configuras.



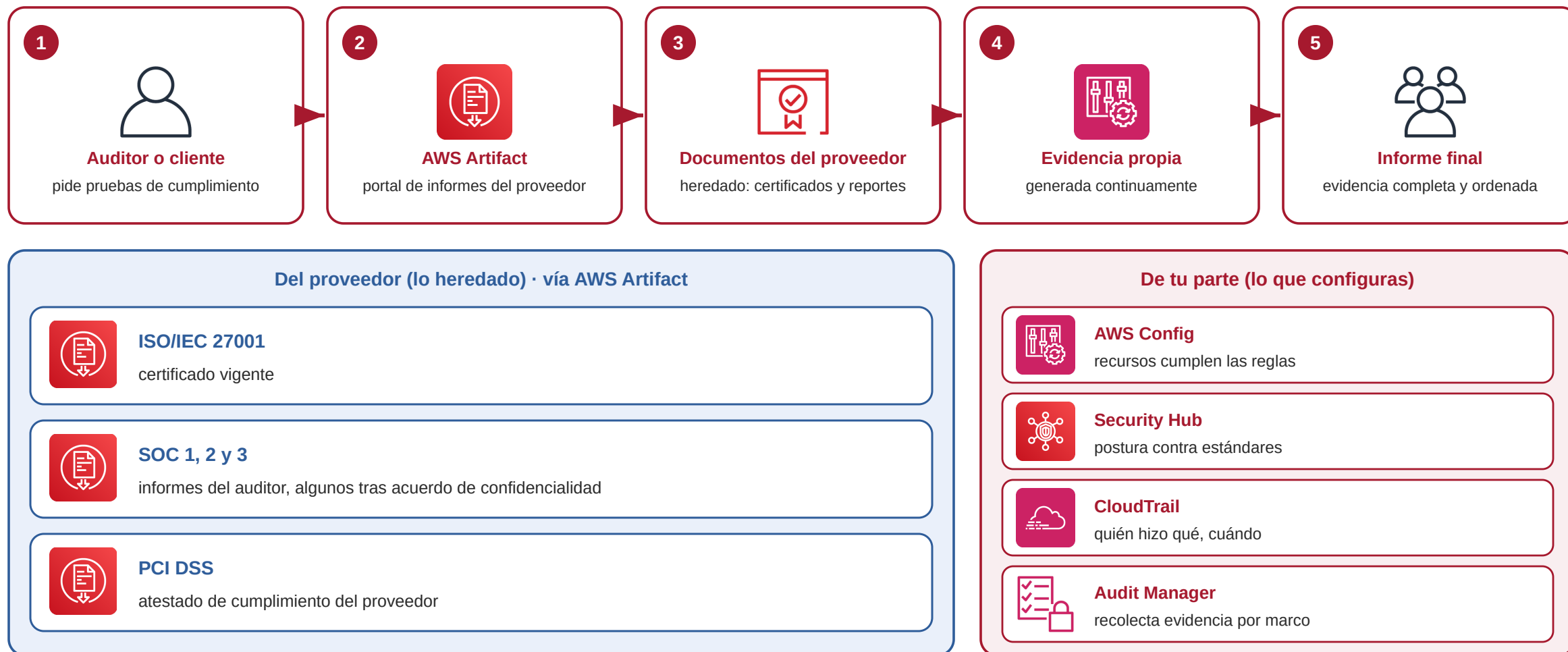


Usar un proveedor certificado no te certifica a ti

Te ahorra controles, pero no los elimina: tu alcance se audita aparte.

AWS Artifact y la evidencia para el auditor

Los informes y certificados del proveedor se descargan; la evidencia de tu parte la generas tú.



Ley 1581 de 2012: habeas data y sus protagonistas

El titular autoriza, el responsable decide el tratamiento y el proveedor cloud actúa como encargado.



Autorización → Responsable → contrato de transmisión → Encargado

Principios (art. 4)



Seguridad y confidencialidad se cumplen con cifrado, IAM y registros

Derechos del titular (art. 8)





Datos sensibles: autorización explícita y protección reforzada

Salud, origen étnico, orientación política, datos biométricos y datos de niños y adolescentes tienen reglas especiales.

La SIC: autoridad, obligaciones y sanciones

La Superintendencia de Industria y Comercio vigila el cumplimiento y puede sancionar con multas y cierres.

Lo que la empresa debe tener listo



Política de tratamiento de datos
publicada y conocida



Aviso de privacidad
dice qué datos y para qué



Autorizaciones
con prueba de que se otorgaron



Consultas y reclamos
procedimiento con plazos

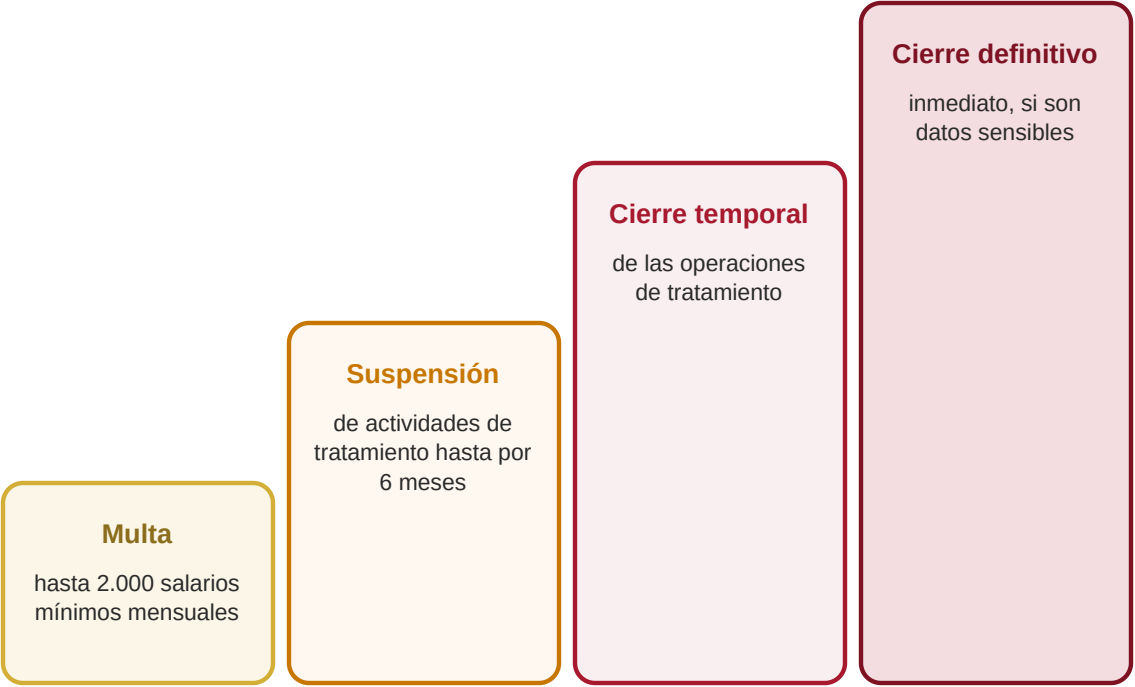


Registro de bases de datos (RNBD)
cuando la empresa está obligada



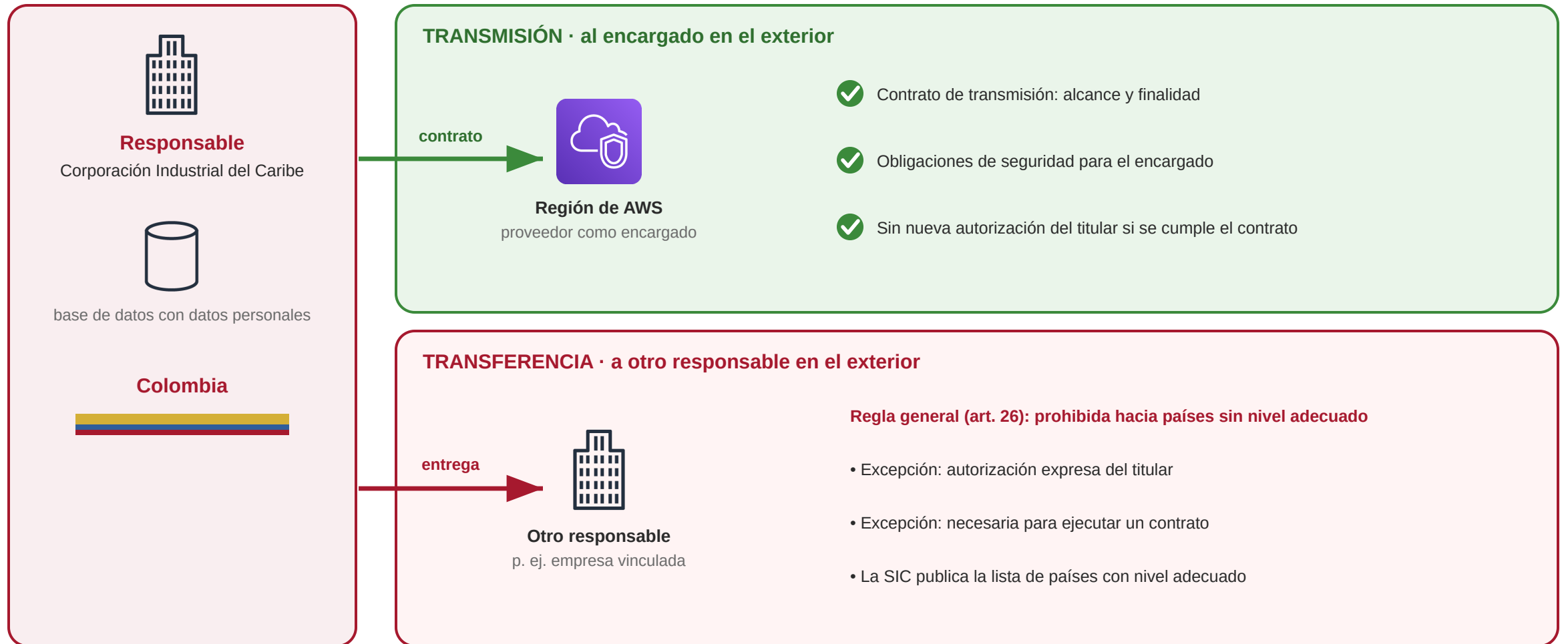
Reporte de incidentes
informar a la SIC violaciones de seguridad

Escalera de sanciones (art. 23)



Transmisión y transferencia: no son lo mismo

Usar una región fuera de Colombia suele ser una transmisión a un encargado, bajo contrato.



Elegir región: legal, técnica y económica

La región es una decisión de cumplimiento; se hace cumplir con controles, no con buenas intenciones.

Criterios, en orden

- 1

Legal y contractual
¿hay límites de residencia?
- 2

Servicios disponibles
¿tiene lo que necesitas?
- 3

Latencia
distancia a tus usuarios
- 4

Costo
varía según la región
- 5

Resiliencia
mínimo dos zonas

Candidatas cercanas

- 

São Paulo
`sa-east-1`
la más cercana en Sudamérica; suele costar más que Virginia
- 

Norte de Virginia
`us-east-1`
la que más servicios ofrece y precios habitualmente bajos
- 

México (centro)
`mx-central-1`
región reciente: verifica el catálogo de servicios

Cómo se hace cumplir

- 

SCP en Organizations
niega las regiones no aprobadas
- 

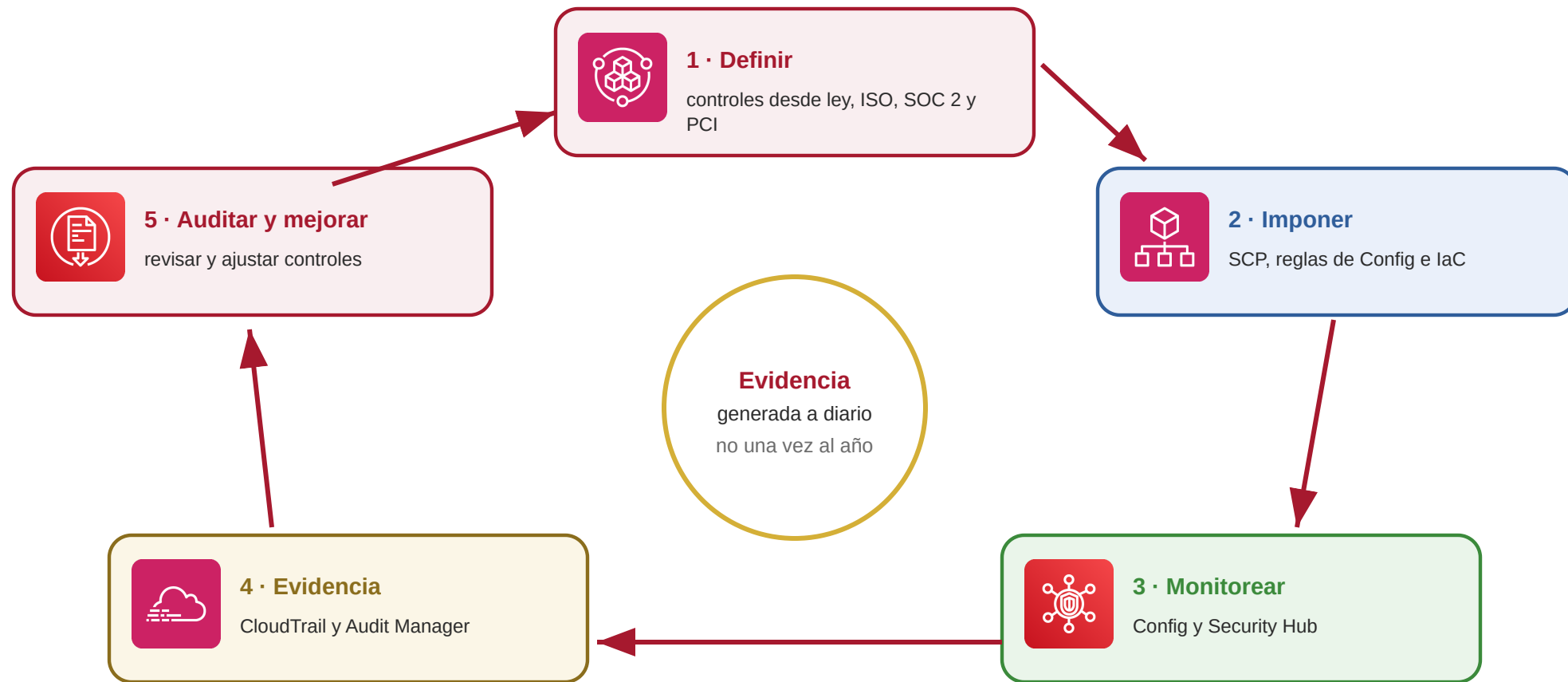
Claves de KMS regionales
el material no viaja entre regiones
- 

Replicación entre regiones
solo si se evalúa y se aprueba
- 

Config y documentación
registro de cada decisión

Cumplimiento como ciclo, no como evento anual

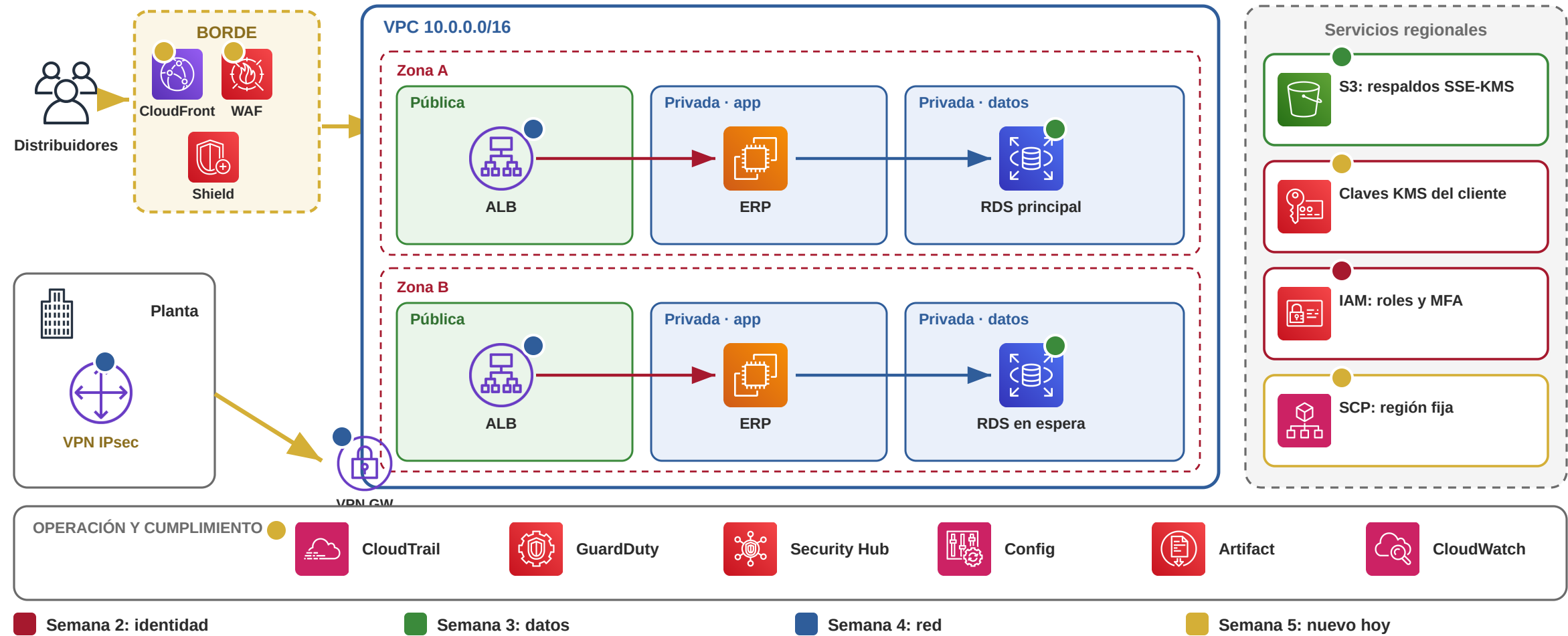
Se definen controles, se imponen como guardarraíles, se monitorean y se guarda la evidencia a diario.



Si la SIC o un auditor pregunta qué medidas tenías en una fecha dada, los registros responden.

Corporación Industrial del Caribe: la arquitectura completa

Identidad, datos, red y seguridad de las cinco semanas, reunidos en una sola arquitectura con evidencia.



Unidad 1 en un mapa, rumbo al Parcial 1

Cada semana se apoya en la anterior: vocabulario, identidad, datos, red y, al final, protección y cumplimiento.



Semana 6 · Repaso de la Unidad 1 y Parcial 1 (20 % de la rúbrica)

Practica explicando la arquitectura de la Corporación con la matriz de responsabilidad compartida a la mano.

Semana 5 en cuatro ideas

La seguridad no es un producto que se compra: es una disciplina de diseño que se demuestra.

1



Responsabilidad compartida

El proveedor asegura la nube; tú, lo que pones en ella; defensa en capas

2



Cifrado y claves

TLS, AES-256, KMS, cifrado de sobre y secretos fuera del código

3



Ver y filtrar

CloudTrail, CloudWatch, GuardDuty, WAF, Shield y Security Hub

4



Cumplir y demostrar

ISO 27001, SOC 2, PCI DSS, Ley 1581 y elección de región

Para llevar: la seguridad no se instala, se diseña en cada decisión

Siguiente: Semana 6 · Repaso de la Unidad 1 y Parcial 1. Después, Unidad 2: cómputo en la nube.



Semana 2



Semana 3



Semana 4



Semana 5